

NMAP e WIRESHARK para Segurança da Informação

Humberto Forsan

Cronograma

Aula 1: Introdução a Redes de Computadores

Aula 2: Modelo OSI

Aula 3: Protocolos de Rede Parte 1

Aula 4: Protocolo de Redes Parte 2

Aula 5: Configurações de Redes

Aula 5.1: Comandos e DHCP

Aula 6: Introdução ao NMAP

Aula 7: Varreduras de Rede com NMAP Parte 1: Host Discovery

Aula 8: Varreduras de Rede com NMAP Parte 2: Host Discovery e Target Specification

Aula 9: Varreduras de Rede com NMAP Parte 3: Scan Techniques, Port Specification e Scan Order

Aula 10: Varreduras de Rede com NMAP Parte 4: OS and Service Detection, Miscellaneous

Aula 11: Varreduras de Rede com NMAP Parte 5: Output e Firewall/IDS Evasion

Aula 11.1: Varreduras de Rede com NMAP Parte 5: Output e Firewall/IDS Evasion

Aula 12: NSE (Nmap Scripting Engine) Parte 1

Aula 13: NSE (Nmap Scripting Engine) Parte 2

Cronograma

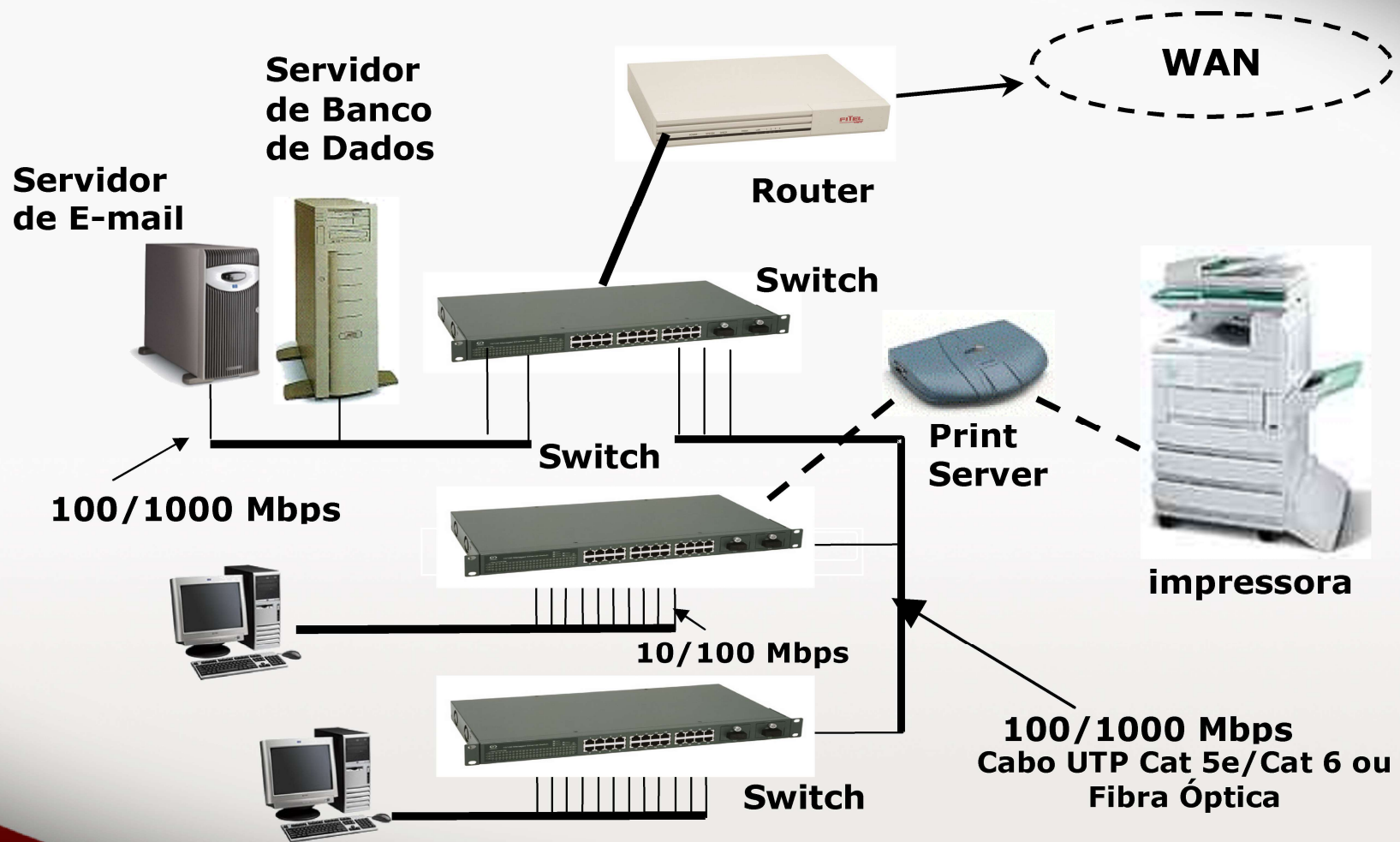
- Aula 14:** NSE (Nmap Scripting Engine) Parte 3
- Aula 15:** Introdução a Segurança da Informação
- Aula 16:** Componentes de Segurança da Informação
- Aula 17:** Tipos de Ataques e Ameaças
- Aula 18:** Análise de Vulnerabilidades com NMAP
- Aula 19:** Introdução Sniffer de Rede
- Aula 20:** Wireshark
- Aula 21:** Wireshark: Interface, Filtros e Coletas
- Aula 22:** Wireshark: Expressões Parte 1
- Aula 23:** Wireshark: Expressões Parte 2
- Aula 24:** Wireshark: SMB
- Aula 25:** Wireshark: HTTP
- Aula 26:** Realizando Arp Spoofing

Aula 1: Introdução a Redes de Computadores

O que são Redes de Computadores?

Redes de Computadores são os compartilhamentos de informações e recursos.

O que são Redes de Computadores?



Vantagens

Computadores distribuídos geograficamente são disponíveis e trocam dados entre si.

Compartilhamento de recursos (hardware e software).

Centralização da Informação e Backup.

Requisitos Mínimos

No mínimo duas entidades para se comunicar ou compartilhar algo (DISPOSITIVOS DE COMUNICAÇÃO).

Um método ou caminho entre as duas (CABO DE REDE, WIRELESS).

Regras definidas e padronizadas para que duas ou mais entidades possam se comunicar (PROTOCOLOS).

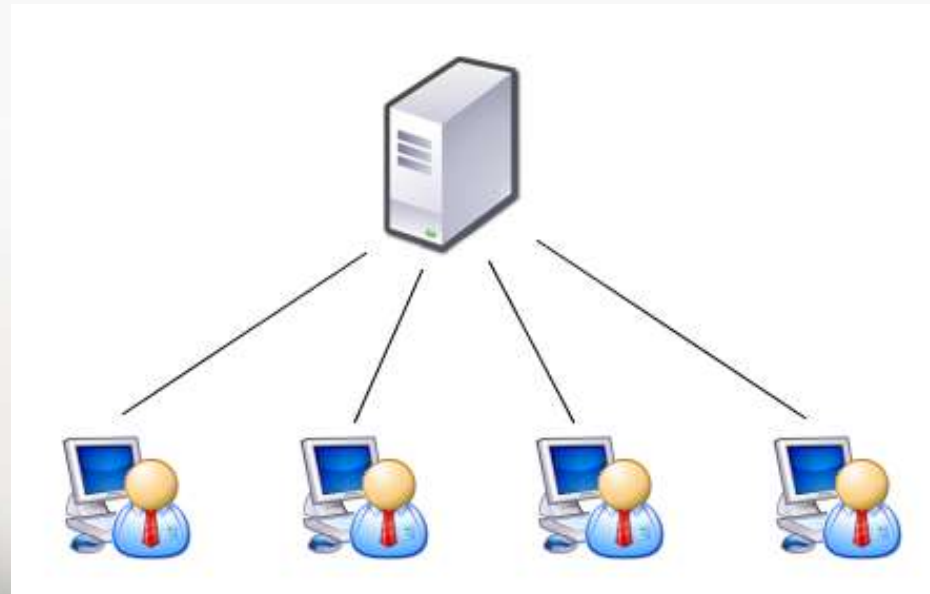
Modelos de Computação

- Computação centralizada;
- Rede distribuída (recursos distribuídos)
- Rede colaborativa (processamento distribuído).

Computação Centralizada

Basicamente, todo o processamento e armazenamento são centralizados em um único servidor.

Trata-se de um único processador de recursos, que é compartilhado por diversos usuários, através do acesso via “terminais” locais ou remotos.



Computação Centralizada



Thin client

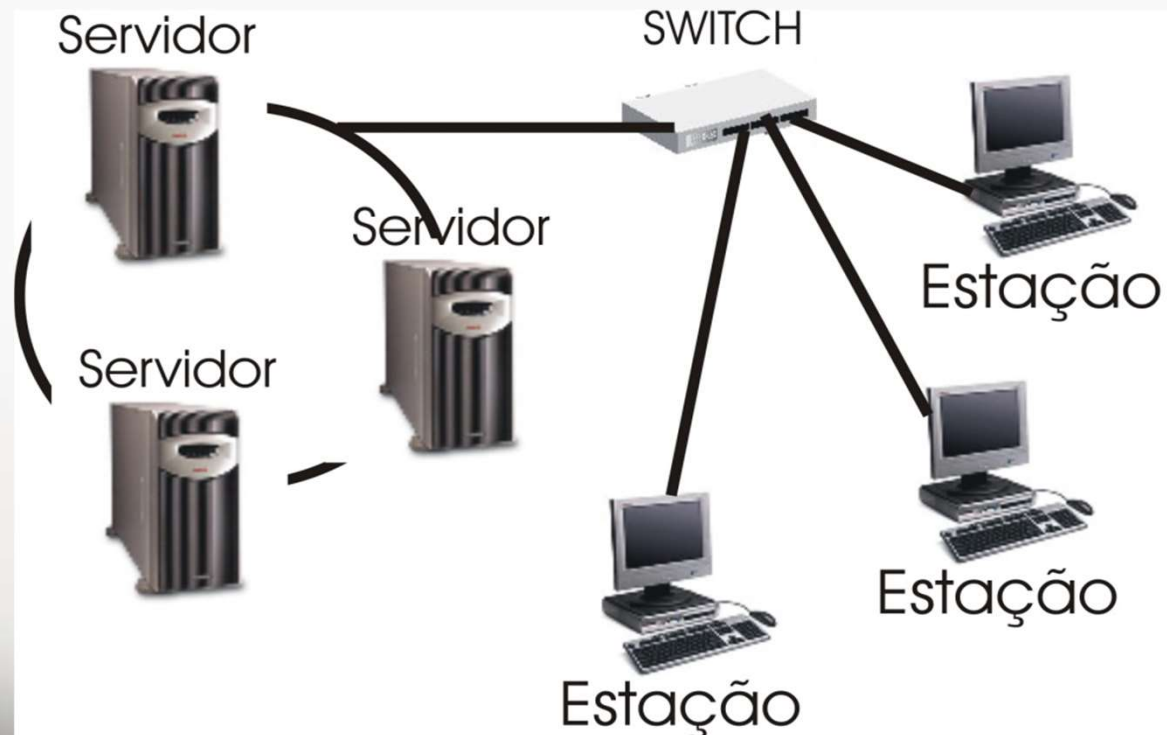
Rede Distribuída

Em vez de centralizar todo o processamento em uma única entidade, a computação distribuída utiliza vários computadores menores para obter os mesmos resultados.



Rede Colaborativa

O modelo de Rede Colaborativa considera o processamento distribuído entre os computadores de toda a rede. Ou seja, ocorre o compartilhamento da capacidade de processamento.



Tipos de Redes (distância entre as estações)

As redes de computadores são classificadas pela distância abrangida.

Tipos de Redes (distância entre as estações)

LAN – Local Area Network	Rede que se limita a se conectar entre si no mesmo ambiente, de uma empresa, instituição ou residência. A LAN podem ser de pequeno ou grande porte.
MAN – Metropolitan Area Network	Rede que abrange uma cidade inteira. Pode se tratar de uma transmissão de internet via rádio ou cabo, podem se ligar a várias LAN que estiverem dentro do seu perímetro.
WAN – Wide Area Network	Redes geograficamente distribuídas, se espalham por um estado, um país ou o mundo todo. São redes de longa distância. A internet é a maior WAN do planeta. São geralmente implementadas e comercializadas pelas empresas de telefonia usando Banda Larga.

Tipos de Redes (distância entre as estações)

LAN (Local Area Network)

As principais características de uma LAN são:

Perímetros bem definidos

Taxas de erros extremamente baixas

Compartilhamento de recursos de hardware e software

Segurança dos Dados

Permite internetwork (interligação de redes distintas)

Os principais equipamentos utilizados em uma rede local são:



Hubs/Switches:

Concentram as conexões da LAN e permitem o uso de meios de cobre de par trançado

Roteadores: Oferece vários serviços, entre eles a interligação entre redes LAN com outros tipos de redes.

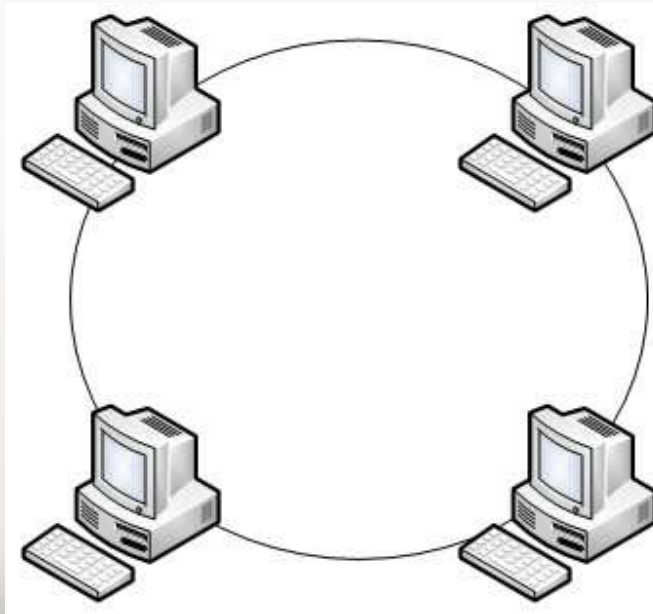


TOPOLOGIAS FÍSICAS DE REDES (tráfego da informação)

A topologia de uma rede descreve como é o layout do meio através do qual há o tráfego de informações e também como os dispositivos estão conectados.

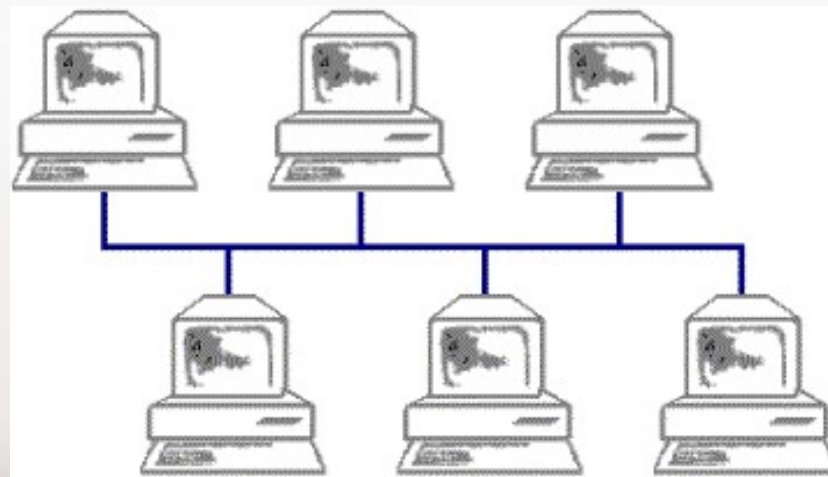
Anel

A rede toma a forma de um anel, com ligações fechadas (anel). A mensagem é repetida de estação para estação até retornar a estação de origem, sendo então retirada do anel. Hoje é um sistema descontinuado.



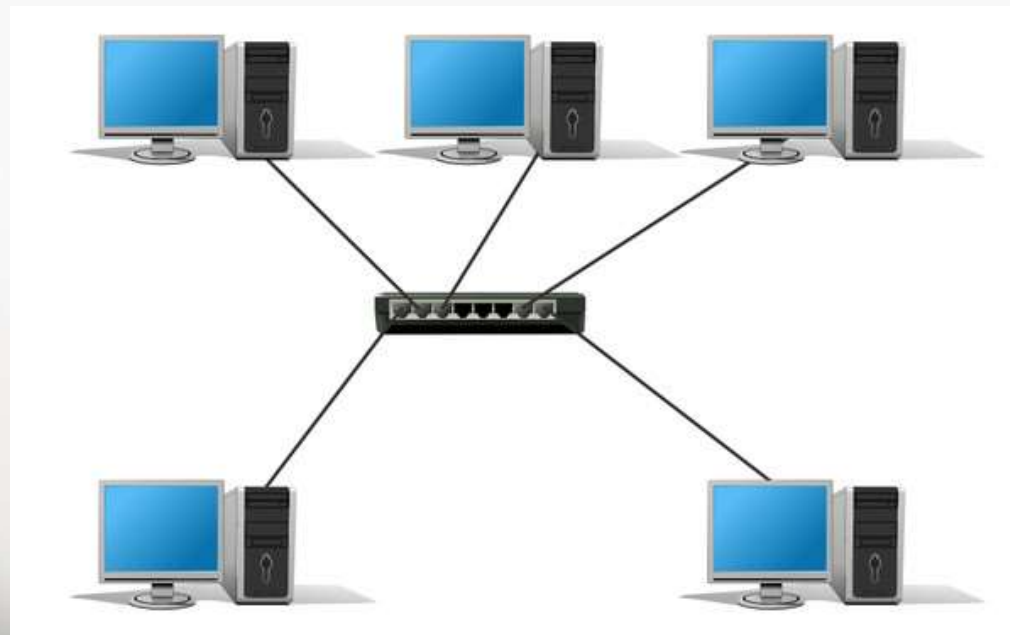
Barramento:

As Estações são conectadas através de um cabo de cobre (coaxial) com difusão da informação para todos os nós. É de fácil expansão, mas de baixa confiabilidade, pois qualquer problema no barramento impossibilita a comunicação em toda a rede. Hoje também é um sistema descontinuado.



Estrela

A Conexão é feita através de um nó central que exerce controle sobre a comunicação, sua confiabilidade é limitada ao seu nó central (Switch). A sua expansão também é limitada ao seu nó central.



NMAP e WIRESHARK para Segurança da Informação

Aula 2: Modelo OSI

Modelo OSI (Open System Interconnection)

Nas primeiras redes, computadores de fabricantes diferente não conseguiam trocar informações

Foi criado então um modelo em camadas para padronizar equipamentos e protocolos de comunicação

O modelo OSI é apenas um modelo de referência mantido pela ISO* criado em 1984

ISO: Organização Internacional para Padronização

Modelo OSI (Open System Interconnection)

Uma rede tipicamente envolve 3 partes:

Dois ou mais dispositivos que se comunicam;

Um canal de comunicação entre os dispositivos
Cabo elétrico (metálico), ótica (fibra ótica) ou wireless;

Protocolos de comunicação

Modelo de referência ISO OSI

O modelo é dividido em 7 camadas e dividido em duas categorias: Superiores e Inferiores

As camadas superiores são relacionadas às aplicações.

As camadas inferiores são relacionadas a transferência de informações



Modelo de referência ISO OSI



Camada 1 – Física: relaciona-se ao hardware da rede, define questões ligadas à voltagem e à velocidade de transmissão, além de tratar da construção dos equipamentos de rede.

Modelo de referência ISO OSI



Camada 2 – de enlace: implanta no meio físico um canal de comunicação.

Quebra as mensagens em quadros de dados, sempre que um receptor recebe um desses quadros, emite de volta uma mensagem de confirmação e o transmissor então envia o próximo.

Além de controlarem a velocidade da transmissão de dados de um dispositivo rápido para outro mais lento.

Padrão Ethernet, 802.11

Modelo de referência ISO OSI



Camada 3 – de rede: controla o direcionamento do fluxo de dados na condução da informação pela rede. Possibilita que os dados passem por vários pontos até serem entregues no destino.

Controla rotas e escolhe os melhores caminhos. Leva em consideração a distância mais curta, congestionamentos ou falhas ocasionadas pelo desaparecimento de um ponto de passagem na rota.

Esta camada possibilita a comunicação entre sub-redes.

Modelo de referência ISO OSI



Camada 4 – de transporte: tem a função de receber dados da camada de rede e fracioná-los em pedaços menores, se isso for necessário.

Organiza os pacotes e os entrega na sequência correta, livres de erros, uma vez que durante a transmissão podem seguir caminhos diferentes, se perderem e ainda chegarem fora de ordem ao destino

Modelo de referência ISO OSI



Camada 5 – de sessão: Administra a sessão, estabelece quando a comunicação se inicia e quando termina. Controla o “diálogo”.

Modelo de referência ISO OSI



Camada 6 – de apresentação: faz a tradução de formato de dados entre máquinas que utilizam formatos diferentes.

Ex: A codificação das letras pode ser diferente, ASCII, ABCDIC da IBM, e daí por diante. São realizadas e convertidas várias interpretações para que a informação recebida seja a idêntica à que foi transmitida.

Modelo de referência ISO OSI



Camada 7 – de aplicação: São protocolos de alto nível que possibilitam que softwares de mesmo tipo troquem informações.

Este nível da rede é responsável pelo formato do conteúdo dos pacotes que estão sendo transmitidos. É constituído de softwares que interagem com o usuário, pois entrega o recurso ao cliente do serviço. Está no fim da rede.

Ex: HTTP, FTP, POP e SMTP

NMAP e WIRESHARK para Segurança da Informação

Aula 3: Protocolos de Rede Parte 1

Protocolos

Cada camada possui seus protocolos conhecidos, como o DNS, correios eletrônicos (POP3 e SMTP), FTP na camada de aplicação, o NFS (Network File System), o protocolo TCP na camada de transporte e o IP na camada de rede.

Protocolo TCP

O TCP – Transfer Control Protocol, ou Protocolo de Transferência com Controle, implementa uma solução confiável de envio de dados fim a fim.

Para garantir a confiabilidade, o TCP demanda uma resposta para cada segmento enviado, sinalizando que o pacote chegou ao destino.

Se a resposta da entrega não chegar à origem durante determinado tempo, o segmento é considerado perdido e reenviado até que se obtenha a resposta de confirmação ou que a quantidade máxima de vezes de reenvio do pacote chegue ao limite

Protocolo TCP

A função do protocolo é realizar a comunicação segura e dividir as mensagens vindas de outras camadas em pacotes menores para que a camada de rede possa repassá-los pelos roteadores.

Quando precisa transmitir dados pela internet, uma aplicação de rede tem que abrir uma porta de comunicação, chamada de **socket**

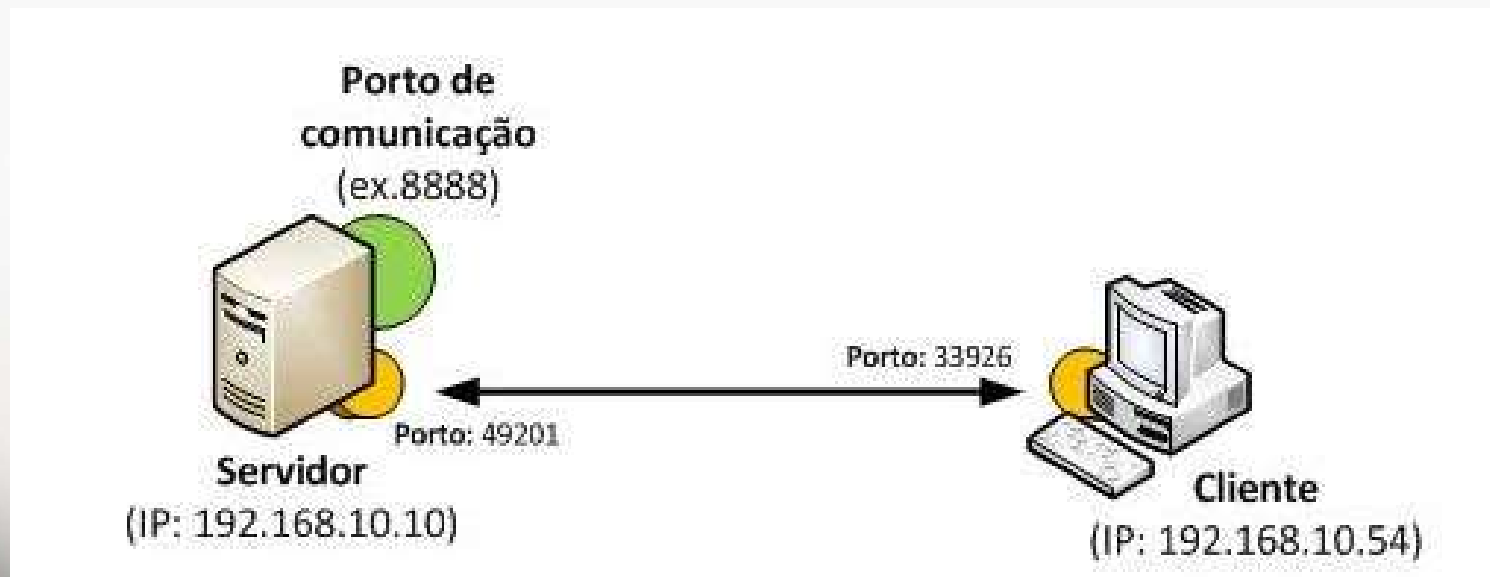


Missão realizada pela camada de transporte.

Protocolo TCP

Além de segmentar as mensagens, acaba sendo papel do TCP assegurar que estas sejam entregues para a aplicação na ordem correta e sem faltar nenhum pedaço.

A conexão é feita socket a socket, pois podem existir vários sockets dentro da mesma aplicação.



Protocolo TCP

O número de cada porta pode variar de 1 a 65535. Porém, os sistemas operacionais não costumam utilizar portas de número inferior a 1023, por serem consideradas reservadas

Exemplo: Protocolo FTP cuja sua aplicação solicita por padrão a porta 21

Protocolo HTTP cuja sua aplicação solicita por padrão a porta 80

Protocolo HTTPS cuja sua aplicação solicita por padrão a porta 443

Protocolo SSH cuja sua aplicação solicita por padrão a porta 22

Protocolo DNS cuja sua aplicação solicita por padrão a porta 53

Entrega TCP (3 Way Handshake)

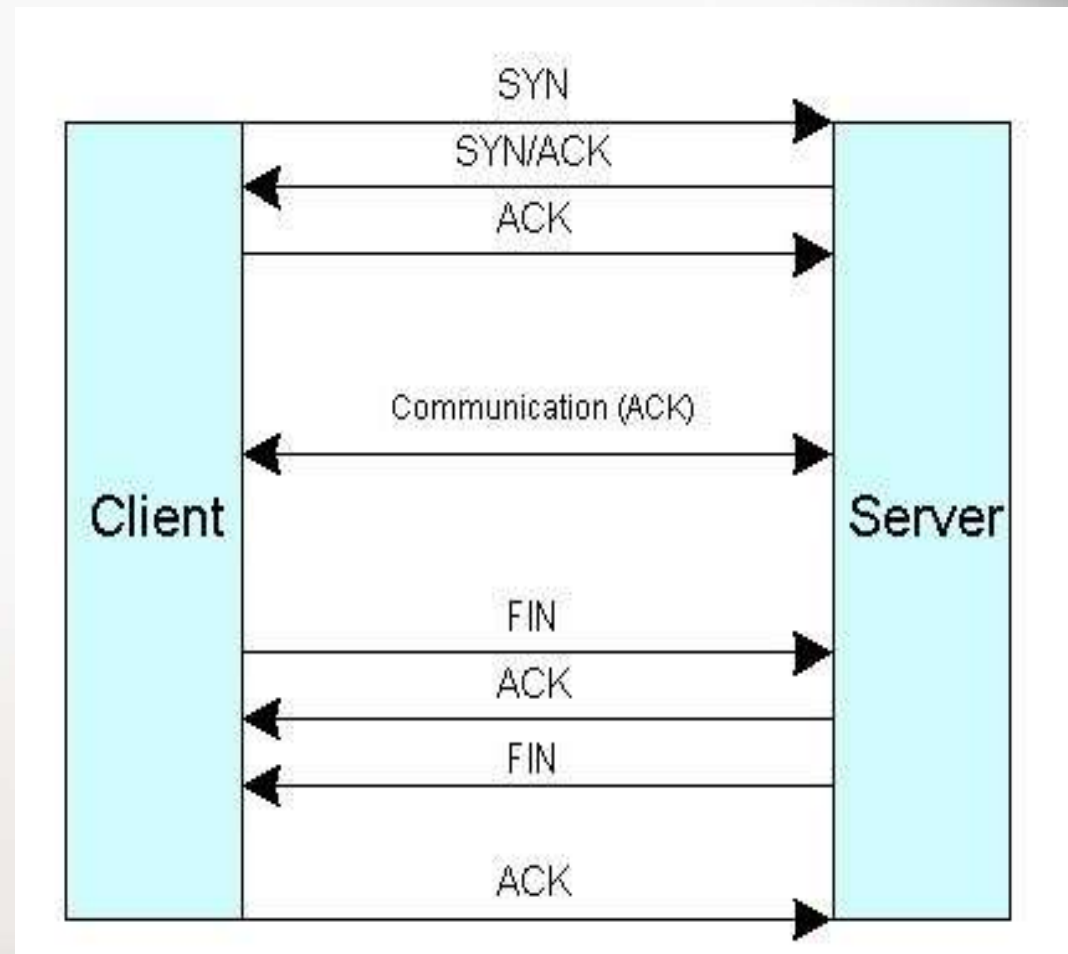
Flags TCP

ACK - Certificação que recebeu o ultimo pacote ou outra resposta.

RST - Reseta a conexão (ocorreu erro ou coisa parecida).

SYN - Inicia conexão.

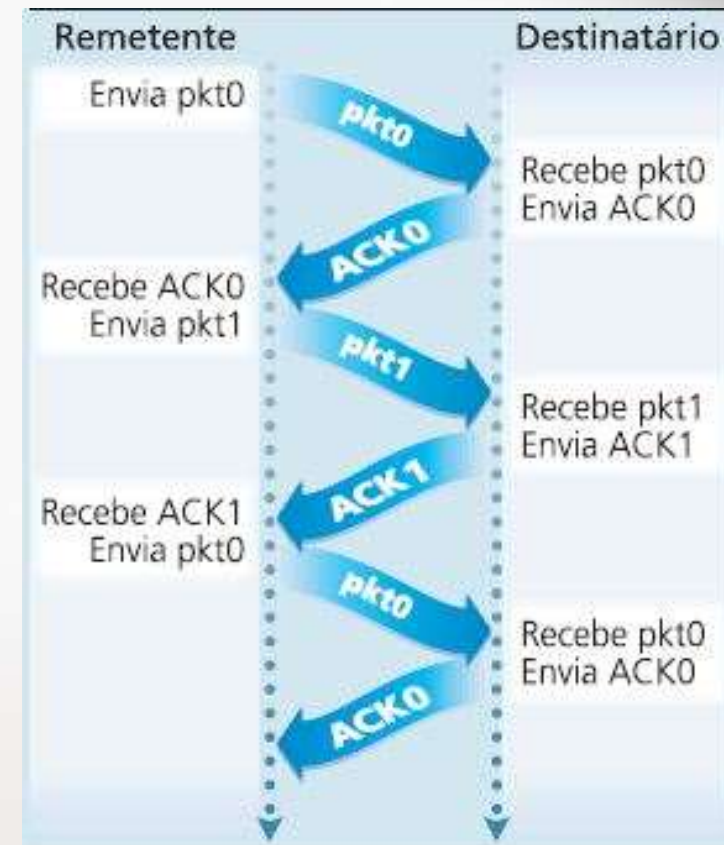
FIN - Termina conexão



Entrega TCP (3 Way Handshake)

A sinalização de entrega é feita por um bit denominado ACK, sigla para a palavra acknowledge (reconhecer), que neste contexto indica que o bit foi aceito no destino.

O TCP também age no controle do sequenciamento dos segmentos, identificando quando um pacote foi enviado duas vezes, ou se falta algum pacote entre os que foram recebidos e encerra a conexão (Handshake).



A internet é uma rede que utiliza o **protocolo IP** como forma de identificar um host e também a origem e o destino dos pacotes.

Protocolo IP (Internet Protocol)

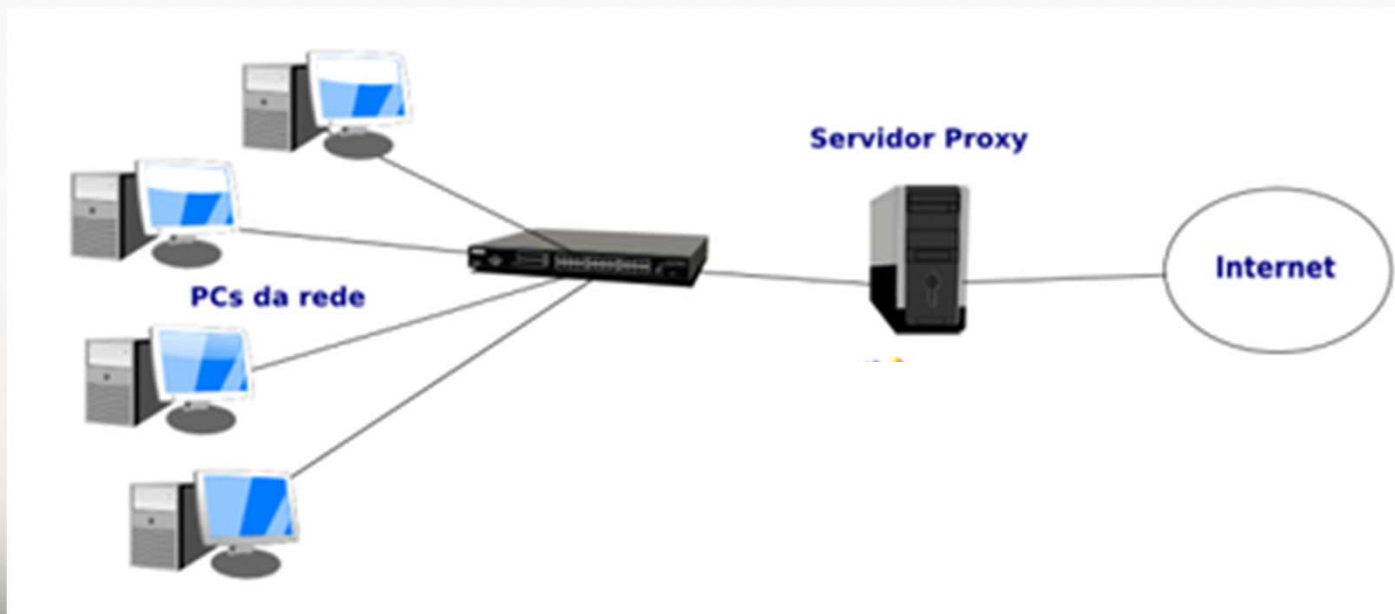
Atualmente, utilizamos a versão 4 do IP, também conhecido por IPv4, essa versão utiliza 32 bits para endereçar até 4.294.967.296 hosts

Por conta dessa “limitação”, poderemos não ter endereços suficientes.

Essa preocupação tem fundamento: há muito mais dispositivos no mundo conectados à internet do que o número de endereços possíveis

Porém, até hoje esse limite não foi alcançado. Isso porque nem todas as máquinas utilizam IP da internet, e sim IP da sua rede interna e compartilham o número IP do servidor ou do roteador.

Isso é possível graças a uma técnica chamada de **NAT** (Natural Address Translation ou Tradução Natural de Endereços).



Endereço IP

Características:

O endereço IP é uma sequência de números composta de 32 bits. Esse valor consiste em um conjunto de quatro grupos de 8 bits. Cada conjunto é separado por um ponto e recebe o nome de octeto ou simplesmente byte.

Exemplo: **192.168.0.1** ou **10.0.0.1**

O endereço IP é dividido em duas partes. A primeira identifica a rede à qual o computador está conectado e a segunda identifica o computador dentro da rede, os primeiros octetos identificarão a rede enquanto os últimos identificarão as máquinas.

Camada de Rede

Originalmente, o espaço do endereço IP foi dividido em estruturas de tamanho fixo chamados de “CLASSES DE ENDEREÇO”.

As principais classes são a **Classe A**, **Classe B** e **Classe C**.

Classe A:

1.0.0.1 – 126.255.255.254 suporta 16.777.216 endereços de rede

Classe B:

128.0.0.1 – 191.255.255.254 suporta 1.048.576 endereços de rede

Classe C:

192.168.0.1 – 223.255.255.254 suporta 65.535 endereços de rede

Camada de Rede

Faixas reservadas de endereços para Rede Local

Classe A:

10.x.x.x

Rede

Classe B:

172.16.x.x – 172.31.x.x

Rede

Rede

Classe C:

192.168.0.x – 192.168.255.x

Rede

Rede

8bits . 8bits . 8bits . 8bits
32bits

Convertendo Bits para Decimal

1 1 1 1 1 1 1 1 = 255
1 2 4 8 16 32 64 128

1bits . 0bits . 0bits . 0bits
1 . 0 . 0 . 0

8bits . 8bits . 8bits . 8bits
32bits

Convertendo Bits para Decimal

1 1 1 1 1 1 1 1 = 255
1 2 4 8 16 32 64 128

8bits . 8bits . 8bits . 8bits
255 . 255 . 255 . 255

Camada de Rede

Na internet, quem controla a distribuição mundial de endereços é Autoridade Atribuidora de Números para Internet

(**IANA** – <http://www.iana.org>), que atribui e repassa o controle regional a entidades chamadas RIRs (Regional Internet Registers).

América Latina e Caribe (LACNIC – <http://www.lacnic.net/pt/>). No Brasil as solicitações devem ser feitas diretamente ao NIC.BR, que é o registro Nacional Internet para o Brasil.

As RIRs vendem faixas de IPs para as provedoras de acesso à internet, que, por sua vez, redistribuem, administram e repassam os custos aos seus clientes.

NMAP e WIRESHARK para Segurança da Informação

Aula 4: Protocolos de Rede Parte 2

Máscara de Sub-Rede

As sub-redes são grupos de hosts que têm o mesmo prefixo IP.

Computadores conectados entre si dentro de uma mesma infraestrutura, ligados a switches ou a um mesmo roteador sem fio formam uma sub-rede.

Camada de Rede

Faixas reservadas de endereços para Rede Local

Classe A:

255.0.0.0

Rede

Classe B:

255.255.0.0

Rede

Classe C:

255.255.255.0

Rede

Faixas reservadas de endereços para Rede Local

Classe A:

255.0.0.0

Rede Hosts



10.x.x.x

Rede Hosts

10.0.0.1

10.255.255.255

\8

Classe A:

255.255.0.0

Rede Hosts



10.x.x.x

Rede Hosts

10.50.0.1

10.50.255.255

\16

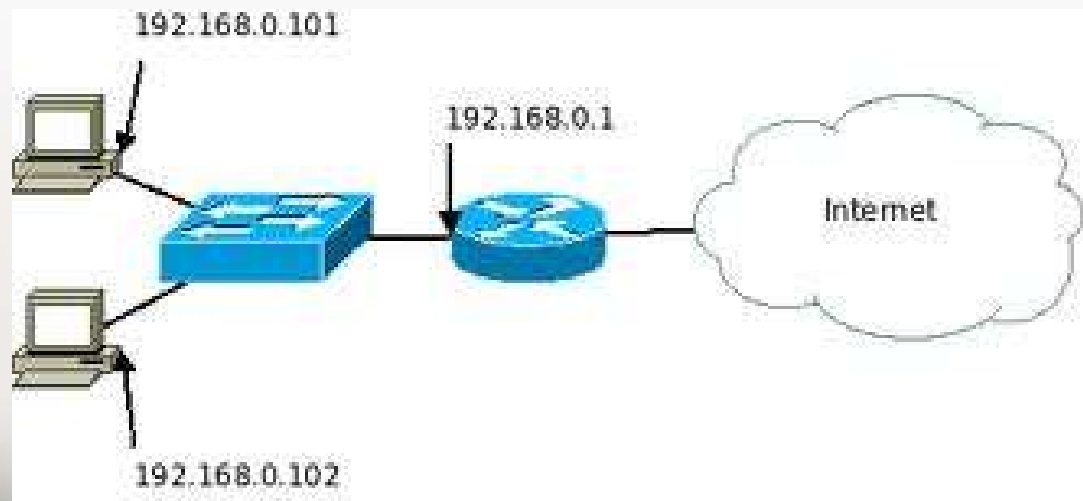
Roteamento

Hosts de uma mesma rede, ou seja, conectada no mesmo barramento, conhecem e repassam as informações entre si

Mas quando um pacote é destinado a um host na internet, esse pacote é encaminhado para o gateway dessa rede.

Podemos dizer que gateway, (gate = portão e way = caminho, caminho do portão), indica que essa máquina tem acesso à saída da LAN, ou seja, a que consegue levar o pacote para fora, ou vice-versa.

Este por sua vez retransmite o pacote a outro gateway seguindo a sua hierarquia.



DNS – Domain Name System

Quando entramos no navegador para acessar uma página qualquer da web digitamos o endereço da homepage como por exemplo, **www.samsec.com.br**. Na barra de endereços a página é carregada.

Para que isso aconteça, a aplicação cliente precisa se conectar com o servidor de páginas na internet que possui o domínio samsec.com.br e está esperando por requisições.

O servidor aceita a requisição e responde pela mesma conexão com o hipertexto solicitado.

Protocolos da Camada de Aplicação

DNS – Domain Name System

Mas como foi possível os roteadores da internet encontrarem esse site?

O que tornou a busca viável foi as aplicações do DNS (Domain Name System, ou Sistema de Nomes de Domínio), um serviço de resolução de nomes.

Sempre que uma conexão é solicitada por meio de um nome, o cliente DNS é acionado. Em seguida, ele se conecta ao seu servidor de nomes requisitando o “IP” do domínio informado

O servidor, por sua vez, acessa uma base de dados de nomes e endereços de IP correspondentes e, caso encontre o relativo à solicitação, responde ao cliente.

DNS – Domain Name System

Como a quantidade de domínios cresceu rapidamente, tornou-se impossível a um único servidor de nomes atender a toda a internet

Por isso foi definida uma hierarquia, constituída por 13 servidores, um em Estocolmo, na Suécia, em Londres, Inglaterra, em Tóquio, no Japão. Todos os demais estão nos Estados Unidos.

Esses servidores delegam o controle dos domínios de determinada região a servidores e, em sua maioria, controlam os domínios de um determinado país.

Cada país tem o próprio sufixo, como .jp (Japão), .uk (Inglaterra), .fr (França), .br (Brasil).

Outros Protocolos

UDP (User Datagram Protocol) é um protocolo da camada de transporte para envio de pacotes de informações, **removendo toda a verificação de erros**. O objetivo é acelerar o processo de envio de dados.

Quando o protocolo UDP é acionado, ele simplesmente manda informações a um destinatário, sem se preocupar se elas foram recebidas devidamente — em caso de erros, simplesmente ocorre o envio do próximo pacote programado pelo sistema, e os anteriores não podem ser recuperados.

O **UDP não é confiável**. Caso garantias sejam necessárias, é preciso implementar uma série de estruturas de controle, tais como timeouts, retransmissões, ack, controle de fluxo, etc.

Cada datagrama UDP tem um tamanho e pode ser considerado como um registro indivisível, diferentemente do TCP, que é um protocolo orientado a fluxos de bytes sem início e sem fim.

UDP (User Datagram Protocol)

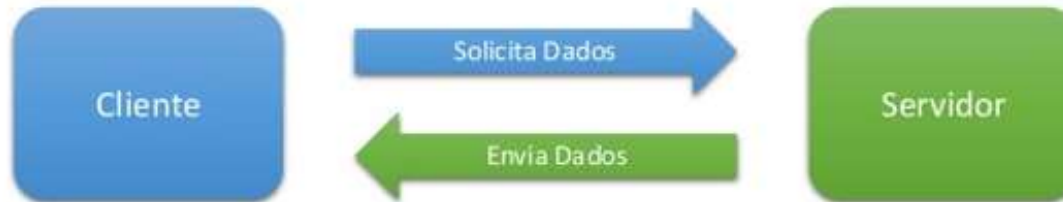
o UDP é um serviço sem conexão, pois não há necessidade de manter um relacionamento longo entre cliente e o servidor.

Um cliente UDP pode criar um socket, enviar um datagrama para um servidor e imediatamente enviar outro datagrama com o mesmo socket para um servidor diferente. Da mesma forma, um servidor poderia ler datagramas vindos de diversos clientes, usando um único socket.

O UDP também fornece os serviços de broadcast e multicast, permitindo que um único cliente envie pacotes para vários outros na rede.

Diferença Protocolo TCP e UDP

Funcionamento do Protocolo UDP



- Funcionamento mais simples
- Mais rápido por ter menos Controles
- Menos Seguro em relação ao recebimento dos Dados (Transporte)
- Não estabelece conexão

Funcionamento do Protocolo TCP



- Funcionamento mais complexo
- Mais Controles
- Mais Seguro em relação ao recebimento dos Dados (Transporte)
- Estabelece conexão antes de transmitir os dados.
- Solicita retransmissão dos dados não recebidos ou corrompidos.

Protocolo HTTP

O Hypertext Transfer Protocol, sigla para **HTTP** é um protocolo de comunicação da camada de aplicação segundo o Modelo OSI

Ele é a base para a comunicação de dados da World Wide Web.

Hipertexto é o texto estruturado que utiliza ligações lógicas (hiperlinks) entre nós contendo texto.

O HTTP é o protocolo para a troca ou transferência de hipertexto normalmente utilizando a porta 80.

Visão técnica geral

O HTTP funciona como um protocolo de requisição-resposta no modelo computacional **cliente-servidor**.

O cliente submete uma mensagem de requisição HTTP para o servidor. O servidor, que fornece os recursos, como arquivos HTML e outros conteúdos.

O protocolo HTTP define oito métodos (GET, HEAD, POST, PUT, DELETE, TRACE, OPTIONS e CONNECT) que indicam a ação a ser realizada no recurso especificado.

OBS: Protocolo com texto em claro.

Ao desenvolver um site dinâmico, existe a necessidade de passar alguns valores de uma página para a outra, para realizar operações como consultas e inserções no banco, autenticação de usuários, etc.

É de extrema importância saber bem a diferença entre os métodos **GET** e **POST**, para que se possa utilizá-los de forma correta e na hora certa.

GET

Com capacidade de 1024 caracteres, este método é utilizado quando se quer passar poucas ou pequenas informações para realizar uma pesquisa ou simplesmente passar uma informação através da URL.

A função do método GET é pura e simplesmente recuperar um recurso existente no servidor.

O resultado de uma requisição GET é “cacheável” pelo cliente, ou seja, fica no histórico do navegador.

Por exemplo:

<http://www.meusite.com.br/index.php?categoria=3&pag=2&tipo=5>

Para entender melhor este exemplo, é preciso olhar para as informações que vem logo após o sinal de interrogação “?”, pois é o símbolo que indica o início dos dados passados através da URL, ou seja, pelo método GET.

POST

Este método utiliza a URI (de Uniform Resource Identifier) para envio de informações ao servidor.

A URI **não é retornável** ao cliente, o que torna o método POST mais seguro, pois não expõe os dados enviados no navegador.

Como não tem limite de capacidade para envio de informações, este método se torna melhor que o GET. No POST, uma conexão paralela é aberta e os dados são passados por ela.

O envio de dados é feito através de formulários (tag <form>), onde são passadas informações para outra página que deverá estar habilitada a recebê-las.

Ao criar formulários de login deve-se utilizar o método POST para troca de informações entre as páginas.

Protocolo HTTPS

HTTPS (Hyper Text Transfer Protocol Secure - protocolo de transferência de hipertexto seguro) é uma implementação do protocolo HTTP sobre uma camada adicional de segurança que utiliza o protocolo **SSL/TLS**.

Essa camada adicional permite que os dados sejam transmitidos por meio de uma **conexão criptografada** e que se verifique a autenticidade do servidor e do cliente por meio de certificados digitais. A porta TCP usada por norma para o protocolo HTTPS é a **443**.

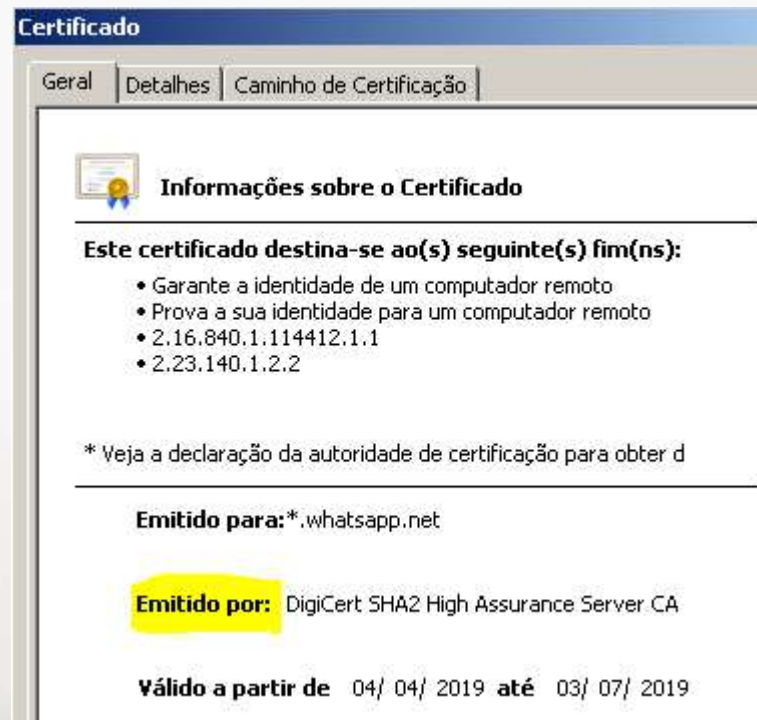
O protocolo HTTPS é utilizado, em regra, quando se deseja evitar que a informação transmitida entre o cliente e o servidor seja visualizada por terceiros, como por exemplo no caso de compras online.

Conexões HTTPS são frequentemente usadas para transações de pagamentos na World Wide Web e para transações sensíveis em sistemas de informação corporativos.

Uma conexão HTTPS pode ser confiável se e somente se todos os itens a seguir são verdade:

- 1- O usuário confia que o navegador implementa corretamente HTTPS com autoridades certificadoras pré-instaladas adequadamente;
- 2- O usuário confia que as autoridades verificadoras só irão confiar em páginas legítimas, que não possuem nomes enganosos;
- 3- A página acessada fornece um certificado válido, o que significa que ele foi assinado por uma autoridade de certificação confiável;
- 4- O certificado identifica corretamente a página (por exemplo, quando o navegador acessa "https://exemplo.com", o certificado recebido é realmente de "Exemplo Inc." e não de alguma outra entidade);
- 5- Ou o tráfego na internet é confiável, ou o usuário crê que a camada de encriptação do protocolo SSL/TLS é suficientemente segura contra escutas ilegais.

A confiança fornecida pelo **HTTPS** é baseada em autoridades de certificação que vêm pré-instaladas no navegador (isto é equivalente a dizer "Eu confio na autoridade de certificação GoDaddy/Microsoft/etc. para me dizer em quem devo confiar").



NMAP e WIRESHARK para Segurança da Informação

Aula 5: Configurações de Redes

Aula Prática

NMAP e WIRESHARK para Segurança da Informação

Aula 5.1: Comandos de Redes e DHCP

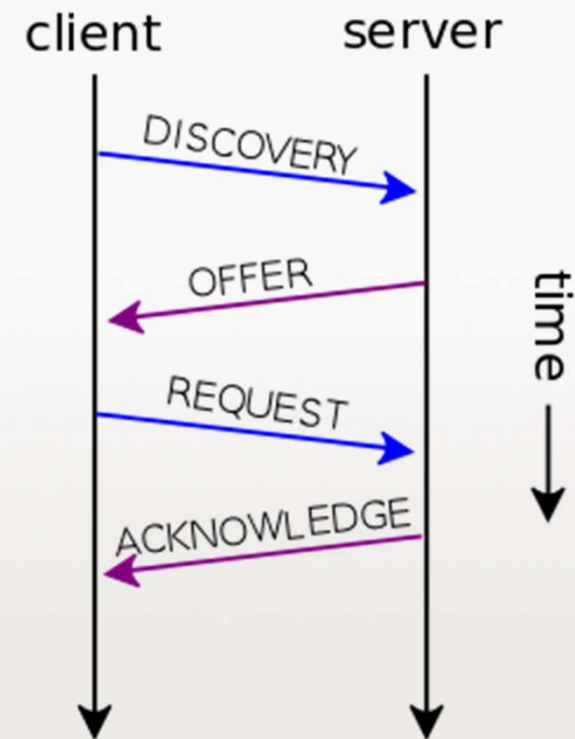
DHCP

DHCP é a sigla para Dynamic Host Configuration Protocol.

Trata-se de um protocolo utilizado em redes de computadores que permite a estes obterem um endereço IP automaticamente.

Quando um computador se conecta a uma rede, ele geralmente não sabe quem é o servidor DHCP e, então, envia uma solicitação à rede para que o servidor DHCP "veja" que uma máquina-cliente está querendo fazer parte da rede e, portanto, deverá receber os parâmetros necessários.

O servidor DHCP responde informando os dados cabíveis, principalmente um número IP livre até então. Caso o cliente aceite, esse número ficará indisponível a outros computadores que se conectarem à rede, já que um endereço IP só pode ser utilizado por uma única máquina por vez.



NETSTAT e NSLOOKUP

Comando para verificação de portas e consulta DNS

Camada de Rede

Se o destinatário estiver em outra filial da empresa, outra residência, cidade ou país, a camada de rede faz com que o pacote seja repassado para vários roteadores

Escolhendo qual a melhor rota, mais curta ou mais rápida.

COMANDO: tracert domínio

EX: tracert tvcultura.com.br

NMAP e WIRESHARK para Segurança da Informação

Aula 6: Introdução ao NMAP



Nmap ("Network Mapper") é uma fonte livre e aberta para descoberta de rede e auditoria de segurança.

O Nmap é possivelmente o scanner de segurança mais amplamente usado em seu gênero

Administradores de rede também acham útil para tarefas como inventário de rede e monitoramento do tempo de atividade do host ou serviço.

O Nmap usa pacotes IP para determinar quais hosts estão disponíveis na rede, quais serviços esses hosts estão oferecendo, quais sistemas operacionais estão executando, que tipo de filtros de pacotes estão em uso e dezenas de outras características.

Foi projetado para varrer rapidamente grandes redes, mas funciona bem em hosts únicos.

O Nmap roda em todos os principais sistemas operacionais de computador, e pacotes binários oficiais estão disponíveis para Linux, Windows e Mac OS X

Além do executável Nmap clássico de linha de comando, também existe o **Zenmap**

No Linux o **nmap** pode ser instalado utilizando a opção de repositórios

Exemplo: Instalação Debian

apt-get install nmap

Para o download dos arquivos de instalação para Windows, Linux e MAC e também o download do Zenmap:

<https://nmap.org/download.html>

Sintaxe:

`nmap [ <Tipo de Scan> ] [ <Opções> ] [ <especificação do alvo> ]`

`nmap 192.168.0.1`

As opções, tipos de scan e alvo do NMAP são divididos nas seguintes categorias:

- HOST DISCOVERY
- SCAN TECHNIQUES
- PORT SPECIFICATION AND SCAN ORDER
- SERVICE/VERSION DETECTION
- SCRIPT SCAN
- OS DETECTION
- TIMING AND PERFORMANCE
- FIREWALL/IDS EVASION AND SPOOFING
- OUTPUT
- MISC
- TARGET SPECIFICATION

Comandos NMAP

-p

Determina qual porta será executada a varredura:

```
nmap -p 80 192.168.0.1
```

```
nmap -p 80,443 192.168.0.0/24
```

```
nmap -p 21,22,8080 192.168.0.1
```

-g

Determina a porta de origem (saída):

```
nmap -g 53 192.168.0.1
```

```
nmap -g 22 192.168.0.0/24
```

NMAP e WIRESHARK para Segurança da Informação

Aula 7: Varreduras de Rede com NMAP Parte 1: Host Discovery

Comandos NMAP

-p

Determina qual porta será executada a varredura:

```
nmap -p 80 192.168.0.1
```

```
nmap -p 80,443 192.168.0.0/24
```

```
nmap -p 21,22,8080 192.168.0.1
```

-g

Determina a porta de origem (saída):

```
nmap -g 53 192.168.0.1
```

```
nmap -g 22 192.168.0.0/24
```

HOST DISCOVERY

-sL (List Scan):

Executa uma varredura apenas para detectar as máquinas que estão “vivas” na rede, retornando uma lista com os endereços IP e o nome do Host (Se conseguir resolver).

```
nmap -sL 192.168.0.0/24
```

-sn (Ping Scan):

Executa uma varredura apenas para detectar as máquinas que estão “vivas” na rede, ele executa um ping, mas desativa a varredura de portas.

```
nmap -sn 192.168.0.0/24
```

HOST DISCOVERY

-Pn (Sem Ping Scan):

Executa uma varredura tratando todos os hosts como on-line, não executa o ping scan e faz a varredura de portas.

```
nmap -Pn 192.168.0.0/24
```

-PS/PA/PU (Ping Scan):

Executa uma varredura utilizando TCP SYN/ACK ou UDP.

```
nmap -PS 192.168.0.0/24
```

```
nmap -PA 192.168.0.0/24
```

```
nmap -PU 192.168.0.0/24
```

NMAP e WIRESHARK para Segurança da Informação

Aula 8: Varreduras de Rede com NMAP Parte 2: Host Discovery e Target Specification

HOST DISCOVERY

-n ou -R (Never do DNS resolution):

Executa uma varredura mas não realiza a consulta de DNS.

```
nmap -n 192.168.0.0/24
```

--dns-servers (Change the DNS Server):

Altera o servidor DNS que está sendo utilizado para resolver os nomes de domínio.

```
nmap --dns-server 8.8.8.8 www.globo.com
```

--traceroute (Trace Route):

Determina a quantidade de saltos até o alvo.

```
nmap -traceroute 192.168.0.1
```

TARGET SPECIFICATION

-iL

Específica uma lista com os hosts

```
nmap -iL Hosts.txt
```

--exclude

Exclui host ou um range da execução do nmap

```
nmap -iL Hosts.txt --exclude 192.168.0.4
```

--excludefile

Excluir uma lista com hosts da execução do nmap

```
nmap -iL Hosts.txt --excludefile Exclude.txt
```

NMAP e WIRESHARK para Segurança da Informação

Aula 9: Varreduras de Rede com NMAP Parte 3: Scan Techniques, Port Specification e Scan Order

SCAN TECHNIQUES

-sS (TCP SYN Scan):

Realiza o envio de um pacote SYN, como uma conexão real e aguarda resposta. Caso um pacote SYN-ACK seja recebido, a porta está aberta. Essa técnica é usada para tentar burlar um sistema de Detecção de Port Scanning (IDS).

```
nmap -sS 192.168.0.1  
nmap -sS 192.168.0.0/24
```

-sn (TCP Null)

Verifica o status da máquina, com a opção -sn ele verifica apenas se a máquina está viva, sem efetuar scan.

```
nmap -sn 192.168.0.1
```

SCAN TECHNIQUES

-sU (UDP)

Executa o scan em portas UDP

```
nmap -sU 192.168.0.1
```

-sO (Protocolo)

Esta análise permite detectar quais são os protocolos (TCP, ICMP, IGMP etc) que o alvo suporta

```
nmap -sO 192.168.0.1
```

-sP (Ping scan)

Para verificar se um determinado host está “vivo” na rede, o NMAP utiliza o ICMP “echo request”. Alguns dispositivos utilizam filtros que bloqueiam os pacotes ICMP, e então enviam o pacote de RST (Reset) e o NMAP entende isso como um host ativo.

```
nmap -sP 192.168.0.1
```

```
nmap -sP 192.168.0.0/24
```

PORT SPECIFICATION AND SCAN ORDER

--exclude-ports

Exclui determinadas portas do Scan.

```
nmap 192.168.0.1 --exclude-ports 80,443
```

-F (Fast Mode)

Realiza a verificação rápida apenas nas portas comuns de serviços.

```
nmap -F 192.168.0.1
```

-r

Executa o scan nas portas consecutivamente, não utilizando busca randonica.

```
nmap -r 192.168.0.1
```

NMAP e WIRESHARK para Segurança da Informação

Aula 10: Varreduras de Rede com NMAP Parte 4: OS and Service Detection, Miscellaneous

OS DETECTION

-O (Enable OS detection)

Executa o scan e tenta descobrir qual o sistema operacional do alvo.

```
nmap -O 192.168.0.1
```

SERVICE/VERSION DETECTION

-sV

Essa opção é utilizada para detectar as versões dos aplicativos instalados. Com essa opção o NMAP executará o arquivo nmap-service-probes que é utilizado para determinar protocolos, nome da aplicação, versão e outros detalhes.

```
nmap -sV 192.168.0.1
```

MISC

-A (Advanced)

Modo scan completo, ativa todas as opções de scan. Incluindo detecção de SO, versão dos aplicativos e traceroute.

```
nmap -A 192.168.0.1
```

-V

Traz a versão do NMAP e informações da máquina local.

```
nmap -V
```

MISC

--iflist

Verificar IP, interface e gateway local

```
nmap --iflist
```

-oN

Gera um relatório do resultado do nmap

```
nmap -oN report scanme.nmap.com
```

TIMING AND PERFORMANCE

-T (Timing Template (0-5))

Você pode definir a velocidade da varredura, quanto maior o número, mais rápido:

```
nmap -T1 192.168.0.1
```

```
nmap -T5 192.168.0.1
```

OUTPUT

-v (Verbose)

Executa o scan, mas ativa o modo verbose

```
nmap -v 192.168.0.1
```

-d (Debug)

Executa o debugging do scan

```
nmap -d 192.168.0.1
```

NMAP e WIRESHARK para Segurança da Informação

Aula 11: Varreduras de Rede com NMAP Parte 5: Output e Firewall/IDS Evasion

OUTPUT

--open

Retorna somente as portas abertas

```
nmap --open 192.168.0.1
```

--packet-trace

Mostra todos os pacotes sendo enviados e recebidos

```
nmap --packet-trace 192.168.0.1
```

> nome do arquivo

Grava a saída do nmap em um arquivo

```
nmap 192.168.0.1 > teste.txt
```

FIREWALL/IDS EVASION AND SPOOFING

-f

Habilita a fragmentação de pacotes para tentar impedir a detecção ou bloqueio por algum sistemas de Firewall ou IPS.

Também podemos habilitar o --mtu aonde será especificado o tamanho dos pacotes.

OBS: Tem que ser multiplo de 8.

Exemplos:

nmap padrão: 1074

nmap -f: 4047

nmap -f --mtu 8: 4058

nmap -f --mtu 16: 2093

nmap -f --mtu 24: 1071

nmap -f --mtu 32: 1125

FIREWALL/IDS EVASION AND SPOOFING

--data-length

O Nmap envia pacotes contendo apenas o cabeçalho. Dessa forma os pacotes TCP têm aproximadamente 60 bytes. Aumentando o tamanho do pacote pode se enganar sistemas de detecção de Port Scan.

```
nmap --data-length 100 192.168.0.1
```

-S

Realiza o Spoof do endereço de origem. Para essa verificação, será necessário especificar a interface e a opção -Pn para cancelar o ping e não aparecer vestígios do ip verdadeiro.

```
nmap -e eth0 -Pn -S 192.168.0.50 192.168.0.1
```

Também pode se usar a opção do --source-port aonde você irá enviar os pacotes através de uma determinada porta:

```
nmap -e eth0 -Pn -S 192.168.0.50 192.168.0.1 --source-port 53
```

NMAP e WIRESHARK para Segurança da Informação

Aula 11.1: Varreduras de Rede com NMAP Parte 5: Output e Firewall/IDS Evasion

FIREWALL/IDS EVASION AND SPOOFING

--spoof-mac

Altera o MAC de envio do pacote.

```
nmap --spoof-mac 88:88:88:88:88:88 192.168.0.1
```

Além de especificar o MAC, também podemos utilizar o nome do fabricante:

```
nmap --spoof-mac Cisco 192.168.0.1  
                  Intel  
                  Apple
```

FIREWALL/IDS EVASION AND SPOOFING

-D

Decoy, permite o envio do scan através de vários endereços IPs, dificultando o processo de identificação durante a execução do port scan.

Também pode ser executado com valores randômicos aonde o NMAP irá gerar a sequencia de endereços IP aleatoriamente.

```
nmap -D 192.168.0.1,192.168.0.2,182.168.0.3 IP_DESTINO
```

```
nmap -D RND:3 IP_DESTINO
```

--source-port

Determina a porta de origem (saída):

```
nmap --source-port 53 192.168.0.1
```

```
nmap --source-port 22 192.168.0.0/24
```

NMAP e WIRESHARK para Segurança da Informação

Aula 12: **NSE** (Nmap **S**cripting **E**ngine) Parte 1

NSE (Nmap Scripting Engine)

Um dos recursos interessantes do **Nmap** é o **Nmap Script Engine (NSE)**, que traz ainda mais flexibilidade e eficiência a ele.

Ele permite a execução de scripts para automatizar tarefas e varreduras de rede.

Os scripts são criados na linguagem de programação **Lua** e permite que seus usuários compartilhem seus scripts com outros usuários do Nmap.

Os scripts são agrupados em várias categorias, incluindo autenticação (**auth**), detecção de hosts (**broadcast**), ataques de força bruta para adivinhar credenciais de autenticação (**brute**), descoberta de uma rede (**discovery**), causando uma negação de serviço (**dos**), explorando alguma vulnerabilidade (**exploit**), etc.

NSE (Nmap Scripting Engine)

O NMAP armazena seus scripts em:
/usr/share/nmap/scripts

Também podemos localizar os scripts por sua extensão *.nse

```
root@kali:/# locate *.nse master
/usr/share/exploitdb/exploits/hardware/webapps/31527.nse
/usr/share/exploitdb/exploits/multiple/remote/33310.nse
/usr/share/golismo/wordlist/fingerprint/httprecon/httprecon.nse
/usr/share/nmap/scripts/acarsd-info.nse
/usr/share/nmap/scripts/address-info.nse
/usr/share/nmap/scripts/afp-brute.nse
/usr/share/nmap/scripts/afp-ls.nse
/usr/share/nmap/scripts/afp-path-vuln.nse
/usr/share/nmap/scripts/afp-serverinfo.nse
/usr/share/nmap/scripts/afp-showmount.nse
/usr/share/nmap/scripts/ajp-auth.nse
/usr/share/nmap/scripts/ajp-brute.nse
/usr/share/nmap/scripts/ajp-headers.nse
/usr/share/nmap/scripts/ajp-methods.nse
/usr/share/nmap/scripts/ajp-request.nse
/usr/share/nmap/scripts/allseeingeeye-info.nse
```

NSE (Nmap Scripting Engine)

Os scripts NSE são carregados usando o **--script**

Você pode ver uma descrição de um script com a **--script-help**

Além disso, você pode passar argumentos para alguns scripts por meio da opção **--script-args**

```
root@kali:~# nmap --script-help whois-domain.nse
Starting Nmap 7.70 (https://nmap.org ) at 2019-08-20 11:29 -03

whois-domain
Categories: discovery external safe
https://nmap.org/nsedoc/scripts/whois-domain.html
  Attempts to retrieve information about the domain name of the target
```

Para atualizar a base de dados dos scripts execute o comando:

nmap --script-updatedb

NSE (Nmap Scripting Engine)

Consultando o Whois de um site:

Whois é um mecanismo que registra domínios, IPs e sistemas na Internet e que serve para identificar o proprietário de um site.

Alimentado por companhias de hospedagem, ele reúne todas as informações pertencentes a uma página, seja ela atrelada, no Brasil, a um CNPJ ou a um CPF.

whois-domain.nse

Verifica o Whois de um determinado site.

```
nmap --script whois-domain.nse uol.com.br
```

Exemplo: `nmap -p80 --script whois-domain.nse padariabrasil.com.br`

NSE (Nmap Scripting Engine)

Consultando os métodos HTTP:

Os principais métodos de comunicação HTTP são: GET e POST.

A diferença entre os métodos GET e POST é a visibilidade na URL.

Uma requisição GET é enviada como string anexada a URL até o servidor, enquanto que a requisição POST é encapsulada junto ao corpo da requisição HTTP e não pode ser vista.

http-methods

Busca os métodos de autenticação HTTP em uma página WEB (GET, POST...)

```
nmap -p80,443 --script http-methods scanme.nmap.org
```

NSE (Nmap Scripting Engine)

Enumeração HTTP:

A enumeração HTTP serve para buscar diretórios em um determinado site ou aplicação.

http-enum.nse

```
nmap --script http-enum.nse scanme.nmap.org
```

Também podemos realizar um scan baseado em um caminho, para isso usamos o:
--script-args e o **http-enum.basepath**.

```
nmap -p80 --script http-enum --script-args http-enum.basepath=/shared/ scanme.nmap.org
```

NMAP e WIRESHARK para Segurança da Informação

Aula 13: NSE (Nmap Scripting Engine) Parte 2

NSE (Nmap Scripting Engine)

Detectando registros DNS de uma organização

nmap --script dns-brute.nse nmap.org

Encontre subdomínios com este script. A detecção de subdomínios associados a um domínio de organizações pode revelar novos alvos ao realizar uma avaliação de segurança.

Os hosts descobertos podem ser hosts virtuais em um único servidor da Web ou podem ser hosts distintos em endereços IP espalhados pelo mundo em diferentes datacenters.

O **dns-brute.nse** script encontrará registros **A** válidos , testando uma lista de subdomínios comuns e encontrando os que forem resolvidos com êxito.

```
Host script results:
| dns-brute:
|   DNS Brute-force hostnames:
|     ipv6.nmap.org - 2600:3c01:0:0:f03c:91ff:fe70:d085
|     chat.nmap.org - 45.33.32.156
|     chat.nmap.org - 2600:3c01:0:0:f03c:91ff:fe18:bb2f
|     *A: 45.33.49.119
|     *AAAA: 2600:3c01:0:0:f03c:91ff:fe98:ff4e
|_
```

NSE (Nmap Scripting Engine)

Realizando o Traceroute com Geo Localização

nmap --traceroute --script traceroute-geolocation.nse globo.com

Execute um traceroute para o seu endereço IP de destino e tenha dados de geolocalização plotados para cada salto ao longo do caminho.

Faz correlacionar os nomes de DNS reversos de roteadores em seu caminho com localizações muito mais fácil.

```
TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   9.45 ms   192.168.43.1
2   61.10 ms  100.72.64.1
3   61.11 ms  186-192-81-5.prt.globo.com (186.192.81.5)
```

NSE (Nmap Scripting Engine)

Detectando o título de uma página WEB em um servidor

nmap --script http-title scanme.nmap.org

Com o NMAP é possível encontrar o título de uma página Web em um servidor.

Esse script apenas facilita a obtenção desses títulos em um conjunto de resultados de um intervalo de endereços IP.

Ter o título da página incluído nos resultados da varredura do Nmap pode fornecer contexto a um host, que pode identificar a finalidade principal do servidor da Web e se esse servidor é um potencial alvo de ataque.

```
PORT      STATE SERVICE  
80/tcp    open  http  
|_http-title: Go ahead and ScanMe!  
443/tcp   closed https
```

NSE (Nmap Scripting Engine)

Detectando Sistemas Operacionais

```
nmap -p 445 --script smb-os-discovery 192.168.1.0/24
```

Determine o **sistema operacional**, nome do computador, nome netbios e domínio com o smb-os-discovery.nse script.

Um caso de uso de exemplo poderia ser usar esse script para localizar todos os hosts do Windows XP em uma rede grande, para que eles possam ser desconectados e descartados (o Windows XP não é mais suportado pela Microsoft).

A principal vantagem de usar o Nmap para algo assim em vez de uma ferramenta nativa da Microsoft é que ele localizará todos os sistemas conectados à rede e não apenas aqueles conectados a um domínio.

NSE (Nmap Scripting Engine)

Detectando Compartilhamentos de Redes

nmap --script smb-enum-shares -p 445 192.168.0.1

Com esse script vamos realizar a enumeração de diretórios de redes compartilhados em uma rede local.

```
Current user access: READ/WRITE
redes:
warning: Couldn't get details for share: NT_STATUS_WERR_ACCESS_DENIED (srvsvc.netsharegetinfo)
Anonymous access: <none>
Current user access: READ/WRITE
```

NMAP e WIRESHARK para Segurança da Informação

Aula 14: NSE (Nmap Scripting Engine) Parte 3

NSE (Nmap Scripting Engine)

Recuperando informações do servidor DHCP

nmap -sU -p 67 --script dhcp-discover 192.168.0.1

Envia uma solicitação DHCPINFORM para um host na porta **UDP 67** para obter todos os parâmetros de configuração local sem alocar um novo endereço.

```
PORT      STATE SERVICE
67/udp    open  dhcps
| dhcp-discover:
|   DHCP Message Type: DHCPACK
|   Server Identifier: 192.168.0.1
|   Subnet Mask: 255.255.255.0
|   Broadcast Address: 192.168.0.255
|   Domain Name Server: 8.8.8.8, 192.168.0.1
|   Router: 192.168.0.1
|_ MAC Address: AC:84:C6:18:FC:EF (Unknown)
```

NSE (Nmap Scripting Engine)

Consultar informações do Apache

nmap -sV --script http-apache-server-status ALVO

Esse script tenta recuperar a página de status do servidor Apache que têm o **mod_status** ativado.

```
80 / tcp http aberto
| http-apache-server-status:
| Título: Status do servidor Apache para example.com (via 127.0.1.1)
| Versão do servidor: Apache / 2.4.12 (Ubuntu)
| Servidor criado: 24 de julho de 2015 15:59:00
| Tempo de atividade do servidor: 53 minutos 31 segundos
| Carga do servidor: 0.00 0.01 0.05
| VHosts:
| _ www.example.com:80 GET / status do servidor HTTP / 1.1
```

NSE (Nmap Scripting Engine)

Consultar informações do MySQL

`nmap --script mysql-info localhost`

```
3306/tcp open  mysql
| mysql-info:
|   Protocol: 10
|   Version: 5.5.5-10.1.38-MariaDB-0+deb9u1
|   Thread ID: 5
|   Capabilities flags: 63487
|   Some Capabilities: ODBCClient, SupportsCompression, Support41Auth, IgnoreSigpipes, IgnoreSpaceBe
foreParenthesis, ConnectWithDatabase, LongPassword, SupportsTransactions, Speaks41ProtocolOld, Found
Rows, DontAllowDatabaseTableColumn, LongColumnFlag, SupportsLoadDataLocal, InteractiveClient, Speaks
41ProtocolNew, SupportsMultipleStatments, SupportsMultipleResults, SupportsAuthPlugins
|   Status: Autocommit
|   Salt: w)c8/"Z"5'c<BuHHp{<T
|_ Auth Plugin Name: 103
MAC Address: 0C:84:DC:D4:EB:1D (Hon Hai Precision Ind.)
```

NSE (Nmap Scripting Engine)

Capturando Hashes do MySQL

* A função Hash é qualquer algoritmo que mapeie dados grandes e de tamanho variável para pequenos dados de tamanho fixo.

Muitas vezes usadas em criptografia de senhas

nmap -p 3306 ALVO --script mysql-dump-hashes --script-args = 'username=root, password=senha'

```
root@debian:/# nmap -p 3306 192.168.0.128 --script mysql-dump-hashes --script-args='username=root,password=teste'

Starting Nmap 7.40 ( https://nmap.org ) at 2019-09-07 09:27 -03
Nmap scan report for 192.168.0.128
Host is up (-0.11s latency).
PORT      STATE SERVICE
3306/tcp  open  mysql
| mysql-dump-hashes:
|_ root:*A00D6EEF76EC509DB66358D2E6685F8FF7A4C3DD
MAC Address: 0C:84:DC:D4:EB:1D (Hon Hai Precision Ind.)
```

NSE (Nmap Scripting Engine)

Capturando Hashes do MySQL

* Lembre-se

CrackStation

CrackStation Password Hashing Security Defuse Security

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

A00D6EEF76EC509DB66358D2E6685F8FF7A4C3DD

☐ Não sou um robô 
reCAPTCHA
Privacidade · Termos

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
A00D6EEF76EC509DB66358D2E6685F8FF7A4C3DD	MySQL4.1+	teste

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

NSE (Nmap Scripting Engine)

Descobrendo usuários do MySQL

nmap --script mysql-enum ALVO

```
root@debian:/# nmap --script mysql-enum 192.168.0.128

Starting Nmap 7.40 ( https://nmap.org ) at 2019-09-07 09:40 -03
Nmap scan report for 192.168.0.128
Host is up (0.015s latency).
Not shown: 995 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
| mysql-enum:
|   Valid usernames:
|   root:<empty> - Valid credentials
|   netadmin:<empty> - Valid credentials
|   user:<empty> - Valid credentials
|   web:<empty> - Valid credentials
|   test:<empty> - Valid credentials
|   sysadmin:<empty> - Valid credentials
|   administrator:<empty> - Valid credentials
|   webadmin:<empty> - Valid credentials
|   admin:<empty> - Valid credentials
|   guest:<empty> - Valid credentials
|_ Statistics: Performed 10 guesses in 1 seconds, average tps: 10.0
MAC Address: 0C:84:DC:D4:EB:1D (Hon Hai Precision Ind.)
```

NMAP e WIRESHARK para Segurança da Informação

Aula 15: Introdução a Segurança da Informação

Segurança da Informação

É a ciência que aplica soluções visando à proteção das informações de empresas ou pessoas, garantindo **confidencialidade**, **integridade** e **disponibilidade**.

Algumas Habilidades do Profissional de Segurança da Informação

AntiVírus

Análise de Vulnerabilidades

Pentest

AntiSpam

Criptografia

Políticas

Proxy Internet

Backup

Disaster Recovery Plan

Firewall

Data Loss Prevention

Gestão de Identidades

IDS/IPS

Proxy Reverso

HACKERISMO

O que se espera da Segurança da Informação?

Identificar as principais **vulnerabilidades**, **falhas de segurança** e **portas de entrada** para códigos maliciosos e/ ou **pessoas mal intencionadas**, protegendo as informações de sistemas computacionais.

O que é informação?

“Informação é um **ativo** que, como qualquer outro ativo importante para os negócios, tem valor e necessita ser protegido”.
(NRB ISO 27002)

Qual o valor da informação?

O valor da informação é determinado pelo valor que o **usuário dá a ela**.

É o usuário que reconhece se é apenas um dado, ou se é uma informação.

Ex: Cadastro de clientes de uma empresa.

Tipos de informação?

A informação pode existir sob várias formas:



Impressa ou
escrita em papel



Transmitida por correio ou
outros meios eletrônicos



Verbal



Armazenada
Eletronicamente

Não importa a forma que a informação toma, ou os meios pelos quais ela é compartilhada ou armazenada. Ela deve sempre ser **apropriadamente protegida.**

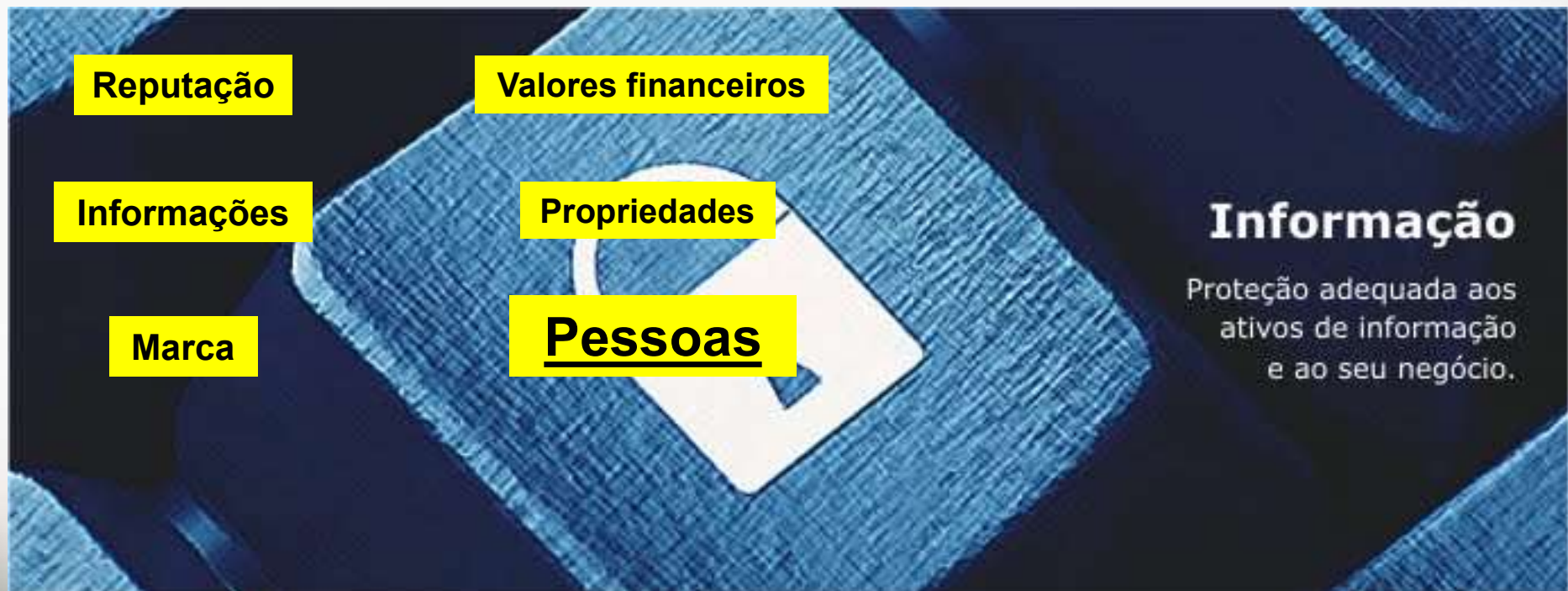
Estado da informação?

- Criada
- Transmitida
- Processada
- Usada
- Armazenada
- Corrompida
- Perdida
- Destruída



Ativos

“Qualquer coisa que tenha valor para a organização”



Ameaças à Informação

- Funcionários **descontentes** ou **desmotivados**
- Baixa **conscientização** nos assuntos de segurança
- Aumento da **eficácia** dos vírus e ameaças
- E-mail
- Inexistência de planos de **recuperação a desastres**
- Desastres (naturais ou não, como incêndio, terremoto...)
- Falta de políticas e procedimentos implementados (Governança de TI)

Riscos

Um risco de segurança é o potencial que uma dada ameaça irá explorar vulnerabilidades para causar perda ou dano a um a ativo.

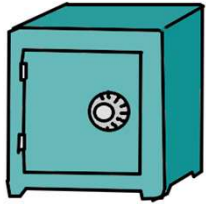
- Interrupção da continuidade do negócio
- Indisponibilidade da informação
- Perda da integridade dos dados
- Perda do controle do serviço
- Perda de credibilidade e imagem
- Perda da confidencialidade de dados

Exemplos de Impactos

O impacto prende-se com o resultado decorrente da verificação de um determinado **evento** de segurança sobre um ou mais recursos, que se traduz normalmente em **consequências** diretas ou indiretas.

- Perda de Clientes e Contratos
- Danos à imagem
- Perda de produtividades
- Aumento no custo do trabalho
- Aumento de seguros
- Penalidades e multas

Tipos de medidas de segurança



- **Prevenção**

Prevenção impossibilita a ocorrência da ameaça ou reduz sua possibilidade. Um exemplo de prevenção é colocar informações sensíveis em um local seguro.



- **Deteccção**

Se as consequências de um incidente não forem demasiadamente grandes, podemos então partir para a solução de detecccção do incidente.



- **Repressão**

Depois de um incidente, precisamos retomar o que foi prejudicado.

Anéis de Proteção da Segurança da Informação



Lembrem-se!

Não existe **mágica** no mundo Hacker...

... o que existe são **Vulnerabilidades**.

Vulnerabilidades

- Fraqueza inerente ao sujeito
- Susceptibilidade ao dano
- Fraqueza específica na proteção do sujeito
- Característica do sujeito

Vulnerabilidades

Vulnerabilidades são fraquezas associadas aos ativos da organização

Vulnerabilidade = Ponto Fraco

Exemplos de vulnerabilidades:

Consultores:

- Contratação inadequada
- Falta de consultores

Instalação:

- Falta de mecanismos de monitoramento
- Proteção física inadequada
- Energia elétrica instável

Informação:

- Falta de Backup
- Armazenamento inadequado
- **Falta de atualizações**

NMAP e WIRESHARK para Segurança da Informação

Aula 16: Componentes de Segurança da Informação

Antivírus

É um software que detecta, impede e atua na remoção de programas de software maliciosos, como **vírus** e worms. São programas usados para proteger e prevenir computadores e outros aparelhos de ameaças, a fim de dar mais segurança a informação



Endpoint Protector

Um sistema de Endpoint Protector é uma evolução dos sistemas básicos de antivírus, eles possuem recursos como IPS, Machine Learning, Sonar, Firewall e Advanced Threat Protection.



AntiSpam

É um sistema de detecção de ameaças oriundas de sistemas de correio eletrônico.

Sua principal função é bloquear ou colocar na quarentena e-mails com anexos, links ou conteúdo suspeito.

Overview > Incoming Mail Summary		
Message Category	%	Messages
Stopped by Reputation Filtering	88.8%	27.6M
Stopped as Invalid Recipients	1.1%	354.0k
Spam Detected	0.4%	118.4k
Virus Detected	0.0%	39
Detected by Advanced Malware Protection	0.0%	0
Messages with Malicious URLs	0.1%	19.1k
Stopped by Content Filter	0.1%	36.9k
Stopped by DMARC	0.0%	0
S/MIME Verification/Decryption Failed	0.0%	0
Total Threat Messages:		90.5% 28.1M
Marketing Messages	0.8%	257.0k
Social Networking Messages	0.2%	58.3k
Bulk Messages	0.8%	238.9k
Total Graymails:		1.8% 554.2k
S/MIME Verification/Decryption Successful	0.0%	0
Clean Messages	7.7%	2.4M
Total Attempted Messages:		31.0M

De: Help Desk [mailto:e_log@mail2webmaster.com]
Enviada em: quinta-feira, 20 de setembro de 2018 06:04
Para: [REDACTED]
Assunto: Querido Usuário

Querido Usuário,

Informamos que a conta [REDACTED].com.br] excedeu o limite de envio de mensagens permitido em nossa política anti-spam. Para evitar que sua conta seja encerrada, estamos atualmente concluindo o processo para reduzir o congestionamento da rede e aumentar a cota de e-mail para melhor atendê-lo. você precisa atualizar este e-mail, fornecendo as informações solicitadas abaixo:



ANTES DE IMPRIMIR PENSE EM SUA RESPONSABILIDADE E COMPROMISSO COM O MEIO AMBIENTE.

As informações contidas nesta mensagem e no(s) arquivo(s) anexo(s) são endereçadas exclusivamente à(s) pessoa(s) e/ou instituição(ões) acima indicada(s), podendo conter dados confidenciais, os quais não podem, sob qualquer forma ou pretexto, ser utilizados, divulgados, alterados, impressos ou copiados, total ou parcialmente, por pessoas não autorizadas. Caso não seja o destinatário, favor providenciar sua exclusão e notificar o remetente imediatamente. O uso impróprio será tratado conforme as normas da empresa e da legislação em vigor. O destinatário deve checar se não há vírus neste e-mail e em seus anexos. A empresa não se responsabiliza pelos danos causados por vírus. Obrigado!

Por favor, preencha as informacoes abaixo

E-mail : [REDACTED].com.br

Nome de Usuario :

Data de Nascimento :

Senha :

Proprietarios de conta que se recusam a cumprir como dito acima pode perder a conta permanentemente.

NETFLIX

⚠ Sua conta está suspensa.

Atualize os dados da sua conta para voltar a assistir e evite o cancelamento.

Há um problema com os dados de pagamento atuais. Tentaremos novamente, mas recomendamos que você atualize essas informações para que não tenha interrupções em suas series e filmes favoritos.

ATUALIZE SUA CONTA AGORA

Precisa de ajuda? Acesse o [entre em contato conosco](#).

- Seus amigos da Netflix

Há um problema com os dados de pagamento atuais.
para que não tenha interrupções em suas series e filmes favoritos.

<http://nirmalmunicipality.in/-/48e616d6dde9dc6efdd617bffd7bb9f8/7f4ff7361287112aa38672083c136466/-/>
<https://netflix.com/?cliente=██████████>

Clique para seguir o link

ATUALIZE SUA CONTA AGORA

Conta Digital (39171)  Caixa de entrada 



Banco Inter noreplay@inter.com.br por 186559.simplecloud.ru
 para eu 

qua, 3 de out 23:37 (Há 54 minutos)

Banco Inter

← → ↻ ⓘ Não seguro | bancinter-clients-785477.duckdns.org/login/atualizacao.php



BANCO
inter

INTERNET BANKING

contadigital

HOME DO SITE

SIMULE NOVOS INVESTIMENTOS

Acesso:

Cliente Conta Corrente / Investimentos

CPF / CNPJ:

CPF ou CNPJ

AVANÇAR

interpag

Com o Interpag,
pagar e receber é:

PRÁTICO



Pelo App

RÁPIDO



Via QR Code

GRATUITO



Zero Tarifa

Fácil, né? Comece a usar!

Antispam

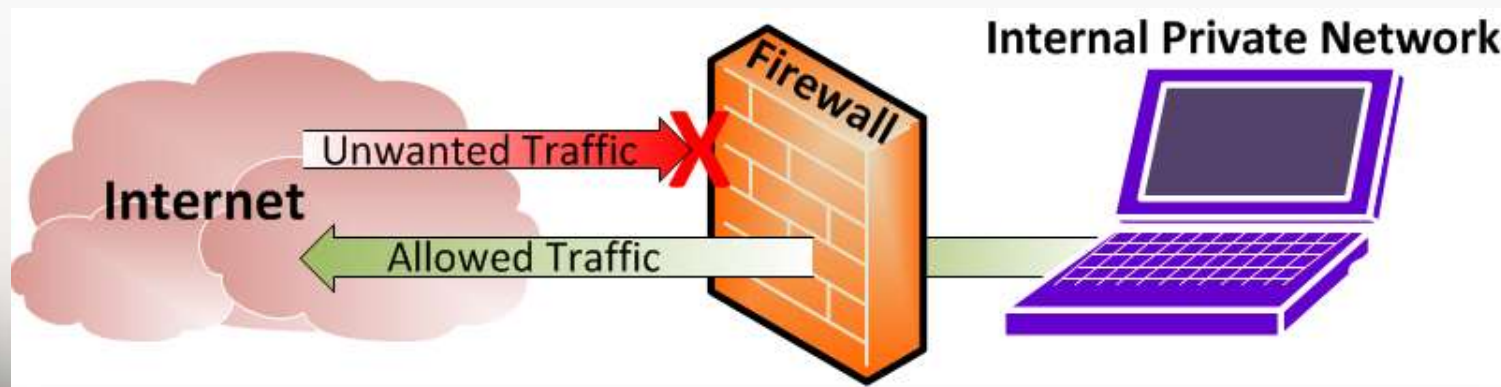
As mensagens que ficarem mais de 30 dias na pasta "Spam" serão excluídas automaticamente. Excluir todas as mensagens de spam agora

Firewall

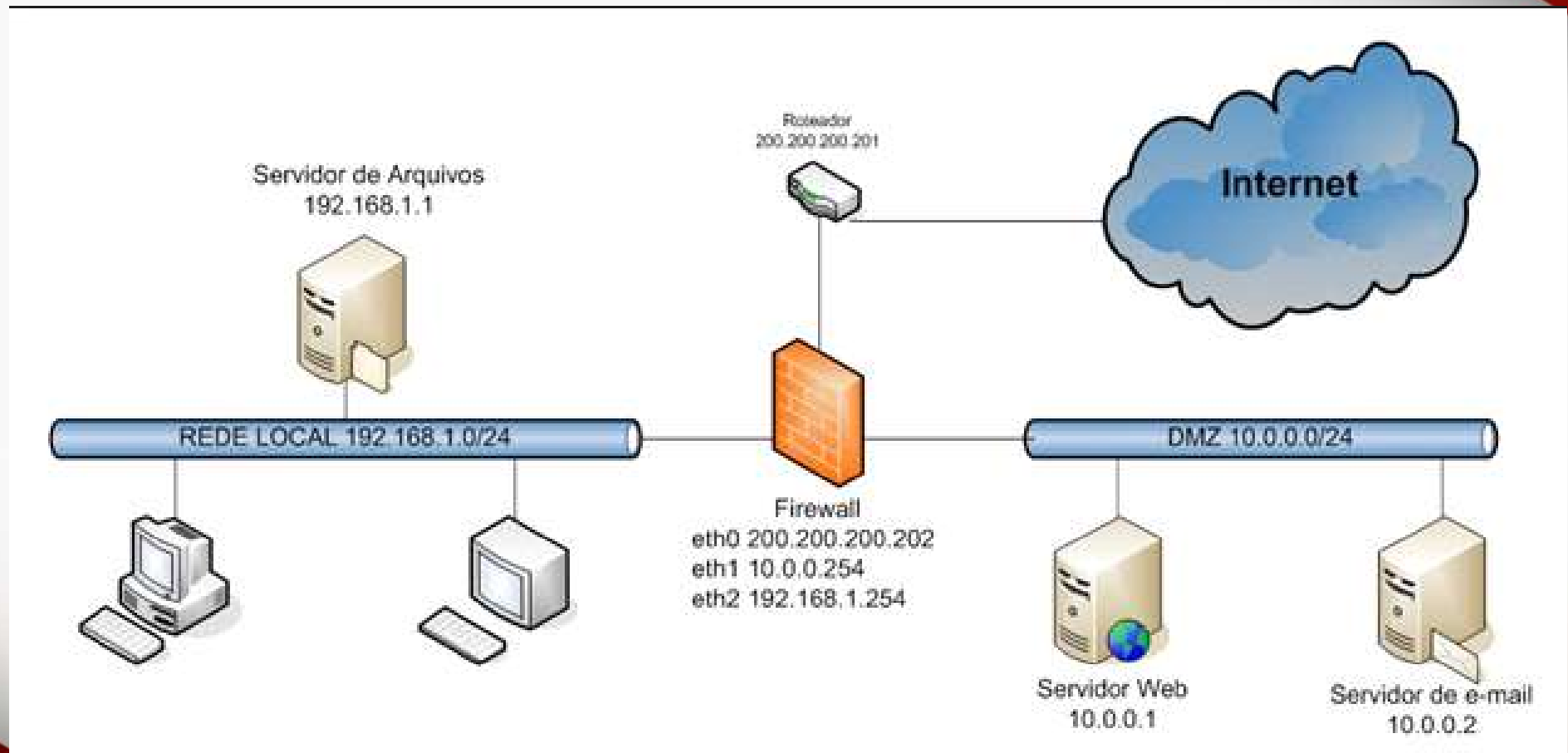
Um firewall é um dispositivo de segurança da rede que monitora o tráfego de rede de entrada e saída e decide permitir ou bloquear tráfegos específicos de acordo com um conjunto definido de regras de segurança.

Os firewalls têm sido a linha de frente da defesa na segurança de rede há mais de 25 anos. Eles colocam uma barreira entre redes internas protegidas e controladas que podem ser redes externas confiáveis ou não, como a Internet.

Um firewall pode ser um hardware, software ou ambos.



Firewall



DMZ é uma sigla para **Demilitarized Zone**

Proxy

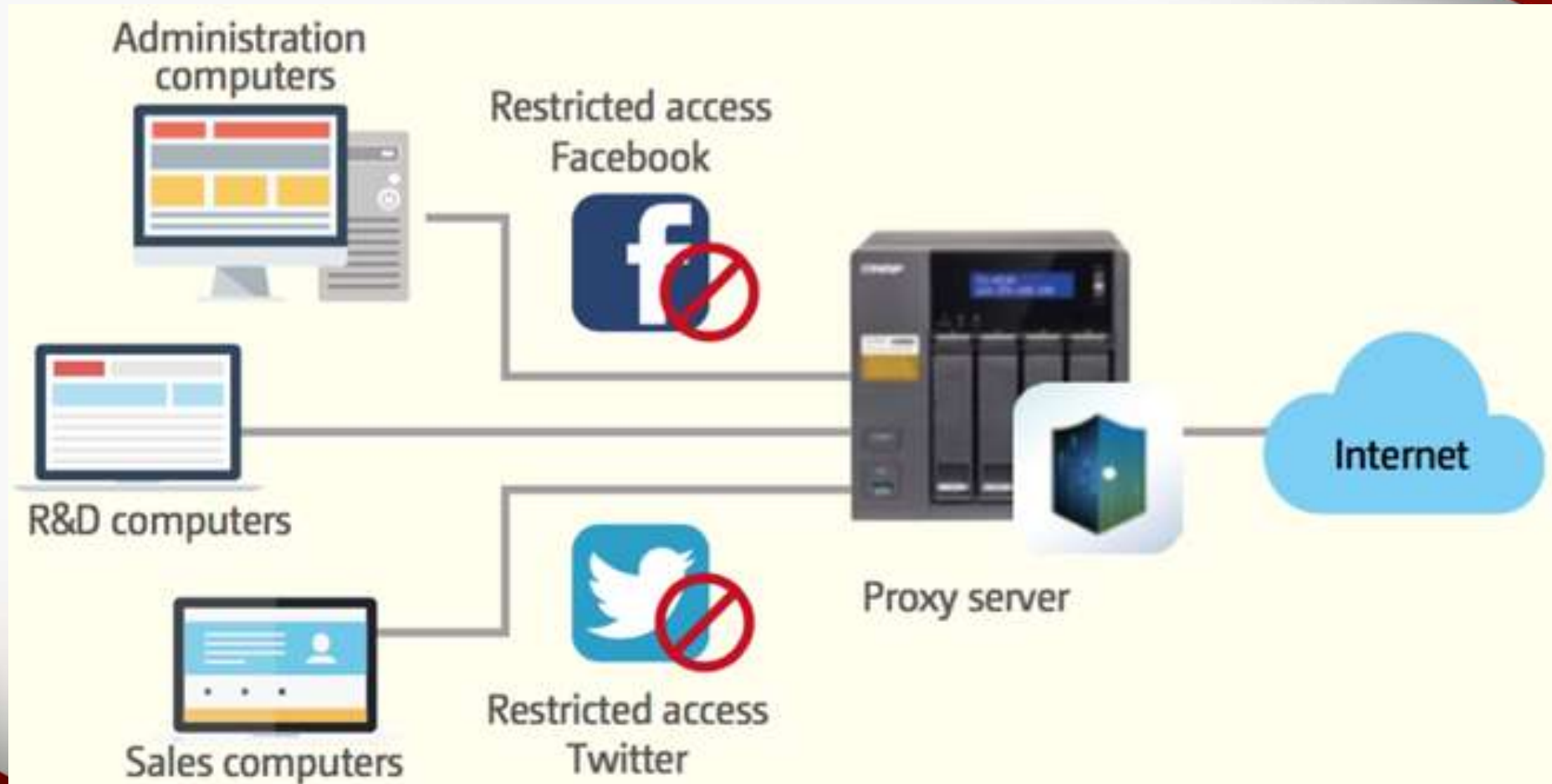
Proxy é o termo utilizado para definir os intermediários entre o usuário e seu servidor.

E por isso desempenha a função de conexão do computador (local) à rede externa (Internet).

Como os endereços locais do computador não são válidos para acessos externos, cabe ao proxy enviar a solicitação local para o servidor.

Criando cache e decidindo a liberação do acesso conforme as políticas de uso do usuário.

Proxy

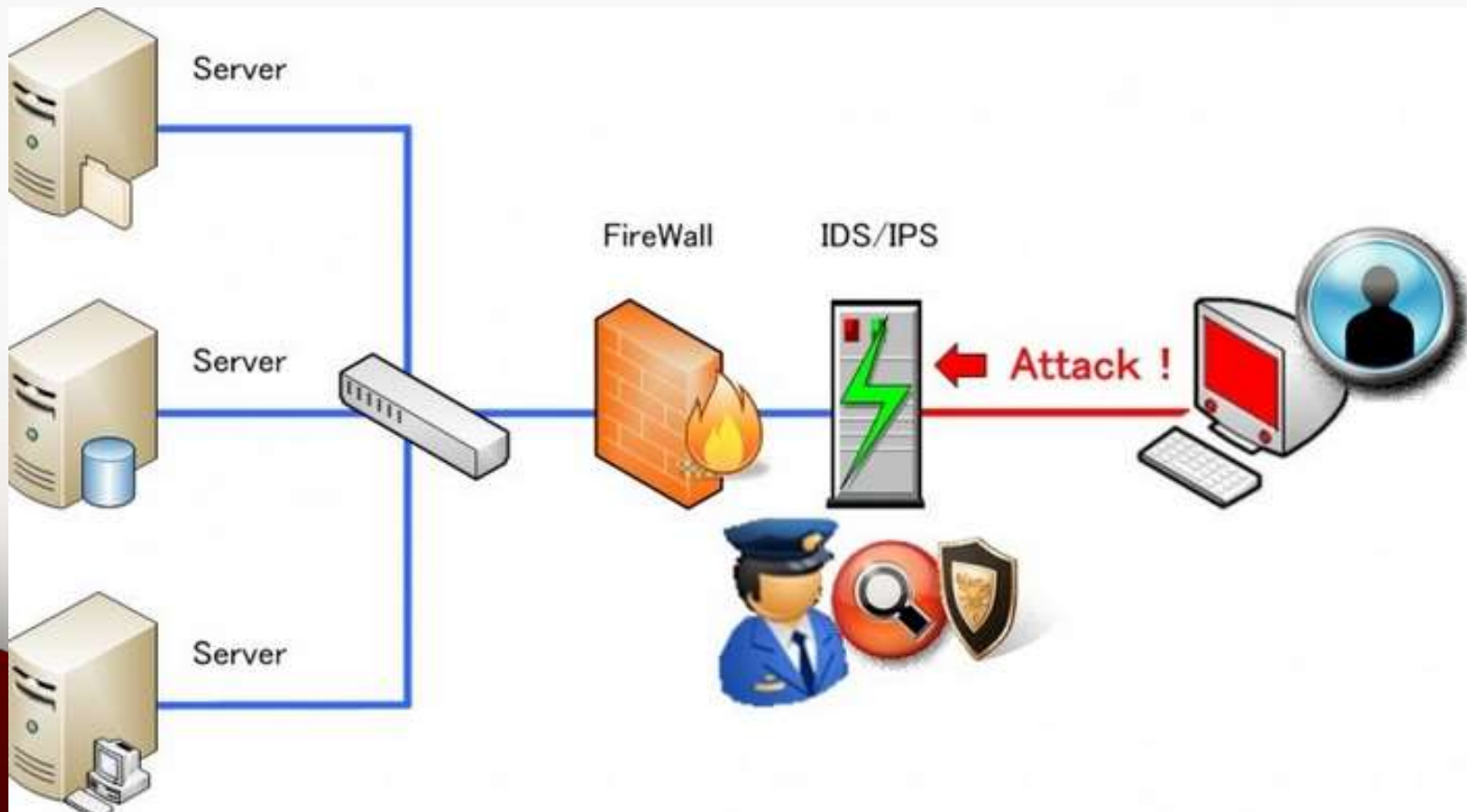


IDS/IPS

São sistemas utilizados para detecção e prevenção de intrusões.

IDS = Intrusion Detection System

IPS = Intrusion Prevention System



IDS/IPS

FortiGate 800C fg_internet_pri										
Log location: Disk HA Cluster FG800C39										
Forward Traffic	#	Date/Time	Severity	3 Source	Protocol	User	Action	Count	Attack Name	
Local Traffic	1	10:14:22		52.89.34.23	tcp		detected	1	MS.IIS.Chunked.Encoding.Transfer.Heap.Overflow	
System Events	2	10:13:41		52.89.34.23	tcp		dropped		HTTP.URI.SQL.Injection	
Router Events	3	10:13:11		52.89.34.23	tcp		dropped		HTTP.URI.SQL.Injection	
VPN Events	4	10:12:44		52.89.34.23	tcp		dropped		HTTP.URI.SQL.Injection	
User Events	5	10:12:42		52.89.34.23	tcp		dropped		HTTP.URI.SQL.Injection	
HA Events	6	10:12:29		52.89.34.23	tcp		dropped	2	HTTP.URI.SQL.Injection	
WiFi Events	7	10:12:14		52.89.34.23	tcp		dropped		HTTP.URI.SQL.Injection	
Web Filter	8	10:12:12		52.89.34.23	tcp		dropped		HTTP.URI.SQL.Injection	
Application Control	9	10:11:59		52.89.34.23	tcp		dropped		HTTP.URI.SQL.Injection	
Intrusion Protection	10	10:11:19		52.89.34.23	tcp		dropped		HTTP.URI.SQL.Injection	
Antivirus	11	10:11:10		52.89.34.23	tcp		dropped		HTTP.URI.SQL.Injection	

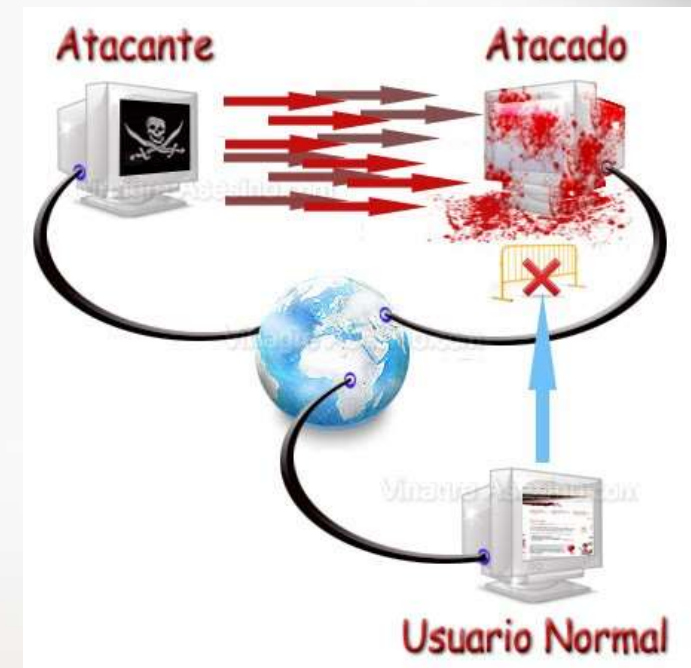
NMAP e WIRESHARK para Segurança da Informação

Aula 17: Tipos de Ataques e Ameaças

DoS ATTACK

Um ***Denial-of-Service Attack*** é uma maneira de derrubar algum serviço ou servidor.

O objetivo aqui é unicamente o de tornar uma página ou processo indisponível para o usuário final.

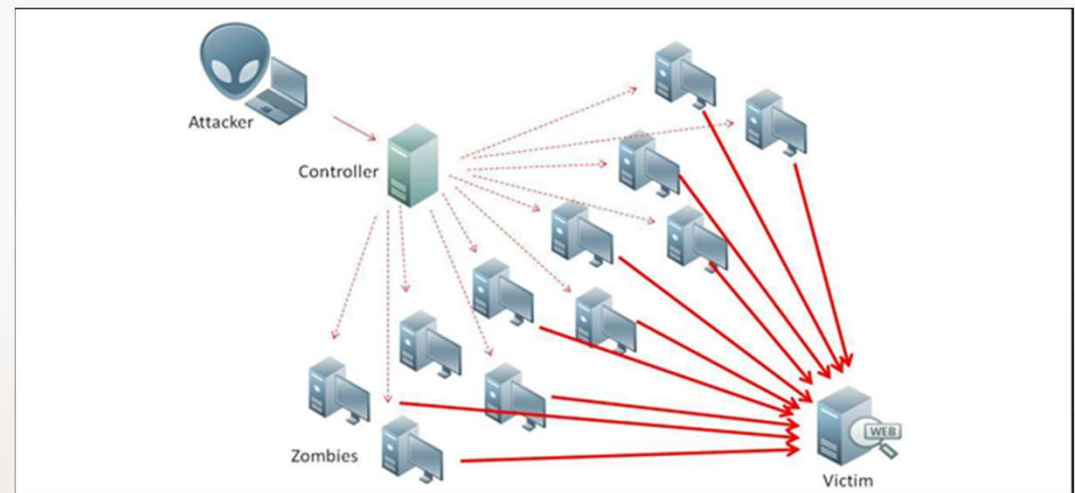


DDoS ATTACK

Quando o atacante escolhe o alvo, ele envia o IP para o mestre, que se encarrega de distribuí-lo por toda a rede zumbi.

Essa rede pode incluir milhares de computadores que são responsáveis por sobrecarregar o alvo até que ele se torne indisponível.

Por ter múltiplas fontes, o rastreamento e bloqueio desse tipo de ataque é bastante complicado.



Port Scanning Attack

Essa é uma técnica utilizada para encontrar portas abertas e **vulnerabilidades** em um determinado servidor.

Utilizada justamente pelos responsáveis pela segurança para encontrar vulnerabilidade, esses ataques normalmente estão relacionados ao uso de softwares maliciosos.

Port Scanning Attack consiste em enviar uma mensagem para uma porta e esperar por uma resposta.

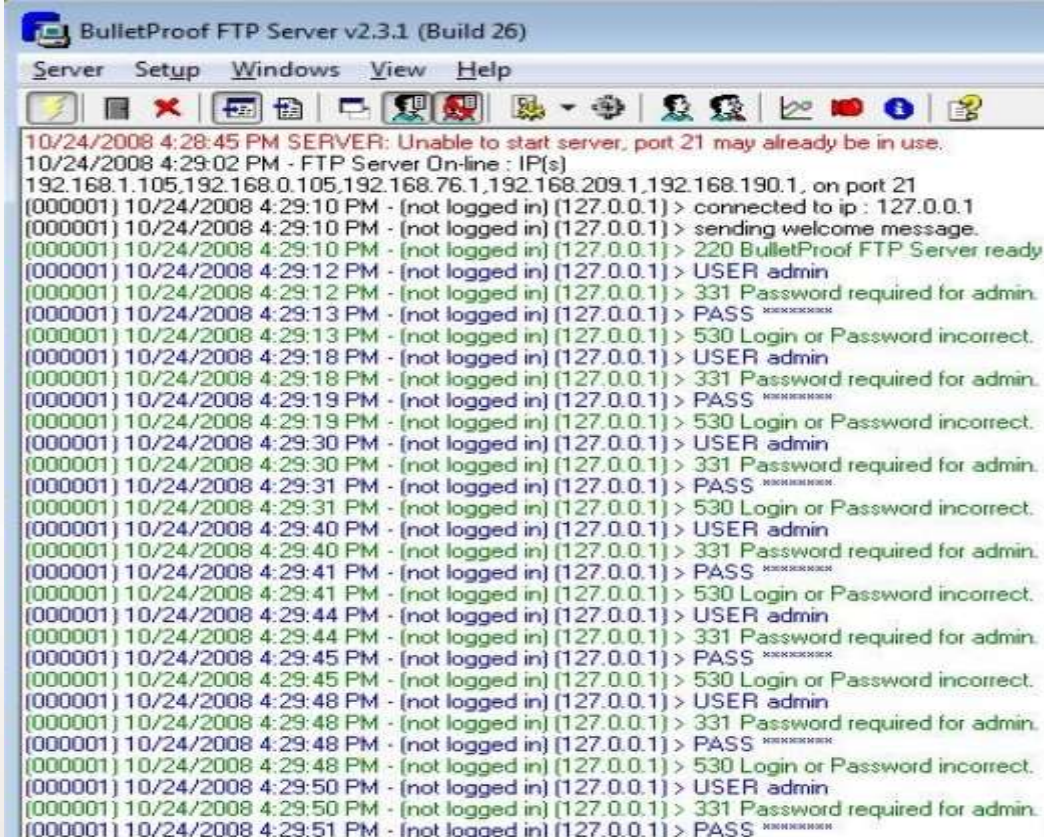
A resposta, então, vai indicar se aquela porta está disponível ou não, o que vai ajudá-lo a encontrar a melhor maneira de obter acesso ao servidor.

Ataques de Força Bruta

Essa é a maneira mais famosa que existe para se quebrar senhas.

Consiste em tentar todas as combinações possíveis até que a senha seja encontrada.

O tamanho das senhas, as combinações possíveis aumentam o tempo necessário para serem decifradas.



```
BulletProof FTP Server v2.3.1 (Build 26)
Server Setup Windows View Help

10/24/2008 4:28:45 PM SERVER: Unable to start server, port 21 may already be in use.
10/24/2008 4:29:02 PM - FTP Server On-line : IP(s)
192.168.1.105,192.168.0.105,192.168.76.1,192.168.209.1,192.168.190.1, on port 21
(000001) 10/24/2008 4:29:10 PM - (not logged in) (127.0.0.1) > connected to ip : 127.0.0.1
(000001) 10/24/2008 4:29:10 PM - (not logged in) (127.0.0.1) > sending welcome message.
(000001) 10/24/2008 4:29:10 PM - (not logged in) (127.0.0.1) > 220 BulletProof FTP Server ready
(000001) 10/24/2008 4:29:12 PM - (not logged in) (127.0.0.1) > USER admin
(000001) 10/24/2008 4:29:12 PM - (not logged in) (127.0.0.1) > 331 Password required for admin.
(000001) 10/24/2008 4:29:13 PM - (not logged in) (127.0.0.1) > PASS
(000001) 10/24/2008 4:29:13 PM - (not logged in) (127.0.0.1) > 530 Login or Password incorrect.
(000001) 10/24/2008 4:29:18 PM - (not logged in) (127.0.0.1) > USER admin
(000001) 10/24/2008 4:29:18 PM - (not logged in) (127.0.0.1) > 331 Password required for admin.
(000001) 10/24/2008 4:29:19 PM - (not logged in) (127.0.0.1) > PASS
(000001) 10/24/2008 4:29:19 PM - (not logged in) (127.0.0.1) > 530 Login or Password incorrect.
(000001) 10/24/2008 4:29:30 PM - (not logged in) (127.0.0.1) > USER admin
(000001) 10/24/2008 4:29:30 PM - (not logged in) (127.0.0.1) > 331 Password required for admin.
(000001) 10/24/2008 4:29:31 PM - (not logged in) (127.0.0.1) > PASS
(000001) 10/24/2008 4:29:31 PM - (not logged in) (127.0.0.1) > 530 Login or Password incorrect.
(000001) 10/24/2008 4:29:40 PM - (not logged in) (127.0.0.1) > USER admin
(000001) 10/24/2008 4:29:40 PM - (not logged in) (127.0.0.1) > 331 Password required for admin.
(000001) 10/24/2008 4:29:41 PM - (not logged in) (127.0.0.1) > PASS
(000001) 10/24/2008 4:29:41 PM - (not logged in) (127.0.0.1) > 530 Login or Password incorrect.
(000001) 10/24/2008 4:29:44 PM - (not logged in) (127.0.0.1) > USER admin
(000001) 10/24/2008 4:29:44 PM - (not logged in) (127.0.0.1) > 331 Password required for admin.
(000001) 10/24/2008 4:29:45 PM - (not logged in) (127.0.0.1) > PASS
(000001) 10/24/2008 4:29:45 PM - (not logged in) (127.0.0.1) > 530 Login or Password incorrect.
(000001) 10/24/2008 4:29:48 PM - (not logged in) (127.0.0.1) > USER admin
(000001) 10/24/2008 4:29:48 PM - (not logged in) (127.0.0.1) > 331 Password required for admin.
(000001) 10/24/2008 4:29:48 PM - (not logged in) (127.0.0.1) > PASS
(000001) 10/24/2008 4:29:48 PM - (not logged in) (127.0.0.1) > 530 Login or Password incorrect.
(000001) 10/24/2008 4:29:50 PM - (not logged in) (127.0.0.1) > USER admin
(000001) 10/24/2008 4:29:50 PM - (not logged in) (127.0.0.1) > 331 Password required for admin.
(000001) 10/24/2008 4:29:51 PM - (not logged in) (127.0.0.1) > PASS
```

Engenharia Social

Engenharia social é termo utilizado para descrever um método de ataque, onde alguém faz uso da persuasão enganando a vítima.

Obtendo informações que podem ser utilizadas para ter acesso não autorizado a computadores ou informações



Phishing

É uma tentativa fraudulenta de obter informações confidenciais , como nomes de usuário, senhas e detalhes de cartão de crédito , disfarçando-se como uma entidade confiável em uma comunicação eletrônica

Geralmente realizado por e-mail

Phishing é um exemplo de técnicas de engenharia social usadas para enganar os usuários. Os usuários costumam ser atraídos por comunicações que alegam ser de partes confiáveis, como sites sociais , sites de leilão , bancos, processadores de pagamento on-line ou administradores de TI.

De: Help Desk [mailto:e_log@mail2webmaster.com]
Enviada em: quinta-feira, 20 de setembro de 2018 06:04
Para: [REDACTED]
Assunto: Querido Usuário

Querido Usuário,

Informamos que a conta [REDACTED] excedeu o limite de envio de mensagens permitido em nossa política anti-spam. Para evitar que sua conta seja encerrada, estamos atualmente concluindo o processo para reduzir o congestionamento da rede e aumentar a cota de e-mail para melhor atendê-lo. você precisa atualizar este e-mail, fornecendo as informações solicitadas abaixo:

[REDACTED] preza pela integridade, transparência e responsabilidade nas relações com todos os seus públicos. Por isso, a informação verdadeira e honesta e o cuidado com a conduta e princípios morais de seus líderes, colaboradores, clientes e fornecedores são sempre valorizados. Qualquer situação irregular deve ser informada via **Canal de Denúncia pelo site** [REDACTED]

ANTES DE IMPRIMIR PENSE EM SUA RESPONSABILIDADE E COMPROMISSO COM O MEIO AMBIENTE.

As informações contidas nesta mensagem e no(s) arquivo(s) anexo(s) são endereçadas exclusivamente à(s) pessoa(s) e/ou instituição(ões) acima indicada(s), podendo conter dados confidenciais, os quais não podem, sob qualquer forma ou pretexto, ser utilizados, divulgados, alterados, impressos ou copiados, total ou parcialmente, por pessoas não autorizadas. Caso não seja o destinatário, favor providenciar sua exclusão e notificar o remetente imediatamente. O uso impróprio será tratado conforme as normas da empresa e da legislação em vigor. O destinatário deve checar se não há vírus neste e-mail e em seus anexos. A empresa não se responsabiliza pelos danos causados por vírus. Obrigado!

Por favor, preencha as informacoes abaixo

E-mail

Nome de Usuario :

Data de Nascimento :

Senha :

Proprietarios de conta que se recusam a cumprir como dito acima pode perder a conta permanentemente.

Remote Code Execution

A execução remota de código é a capacidade que um invasor tem de acessar o dispositivo de computação de outra pessoa e fazer alterações

Não importa onde o dispositivo esteja geograficamente localizado.

As vulnerabilidades podem fornecer a um invasor a capacidade de executar códigos mal-intencionados e assumir o controle total de um sistema afetado com os privilégios do usuário que está executando o aplicativo.

Buffer Overflow

Um buffer é uma seção sequencial de memória alocada para conter qualquer coisa, desde uma cadeia de caracteres até uma matriz.

Um estouro de buffer, ou saturação de buffer, ocorre quando mais dados são colocados em um buffer de comprimento fixo que o buffer pode manipular.

A informação extra, que precisa ir a algum lugar, pode transbordar para um espaço de memória adjacente, corrompendo ou substituindo os dados contidos naquele espaço

Esse estouro geralmente resulta em uma falha no sistema, mas também cria a oportunidade para um invasor executar código arbitrário ou manipular os erros de codificação para solicitar ações maliciosas.

Buffer Overflow

```
Enter the password :  
hhhhhhhhhhhhhhhhhhhhhhhhhhhhhh  
Wrong Password  
Root privileges given to the user
```

Se a aplicação não tratar o erro na entrada dos dados pode permitir a exploração de falhas.

Keylogger

Trata-se de um programa desenvolvido para gravar tudo que o usuário digita no computador.

Funciona como um Spyware, mas é utilizado na maioria das vezes para capturar senhas e dados pessoais.

A infecção ocorre por meio de mensagens instantâneas, links, e-mails, serviços de trocas de mensagens por voz, links, etc.

Ataques SSL

O SSL (Secure Socket Layer) foi um padrão global no que diz respeito a criptografia virtual.

O ataque tem o nome de **Padding Oracle On Downgraded Legacy Encryption**, ou apenas POODLE. O ataque permite o roubo de cookies em conexões HTTPS, o que permite um atacante logar em sites como se fosse a vítima.

POODLE se aplica somente no protocolo SSL 3.0, que foi lançado em 1996. O SSL 3.0 já se tornou obsoleto quando o TLS 1.0 foi lançado em 1999

Backdoor: É um tipo de trojan (cavalo de troia) que permite o acesso e o controle do sistema infectado.

Vírus e Worms: Normalmente se aderem a um sistema de forma que possam inviabilizar o uso de uma máquina ou de uma rede de computadores.

Cavalos de Troia: São aplicações que contêm um agente malicioso oculto, que quando executado infectam o equipamento. Normalmente não causam danos ao sistema, mas liberam acessos e portas de rede.

Ransomware: É um código malicioso (Trojan) que torna inacessíveis os dados armazenados, geralmente usando criptografia, exigindo pagamento de resgate (ransom) para restabelecer o acesso ao usuário.

NMAP e WIRESHARK para Segurança da Informação

Aula 18: Análise de Vulnerabilidades com NMAP

Análise de Vulnerabilidades

A técnica de análise de vulnerabilidades consiste em **detectar** fraquezas, características e susceptibilidades a ameaças

As etapas para detecção, remoção e controle exigem acompanhamento de **profissional qualificado** e **ferramentas específicas**.

Todas as ações tomadas devem ser **documentadas** não só para controlar futuras ações, como também para consultas periódicas.

Origem das Vulnerabilidades

Qualquer sistema que manipule dados está sujeito a alguma vulnerabilidade.

A conexão com a Internet representa uma das principais formas de desestabilização e roubo de informações para qualquer Usuário dentro de uma Organização.

A cada dia novas vulnerabilidades surgem em decorrência de brechas em softwares, imperfeições na configuração de aplicativos e falha humana.

Objetivos da Análise de Vulnerabilidades

A Análise de Vulnerabilidades é responsável por garantir a detecção, remoção*** e controle das vulnerabilidades.

***** Quem faz a análise de vulnerabilidades , pode ser responsável pela correção dela?**

Com isso...

Identificamos falhas de softwares que possam comprometer seu desempenho, funcionalidade e segurança;

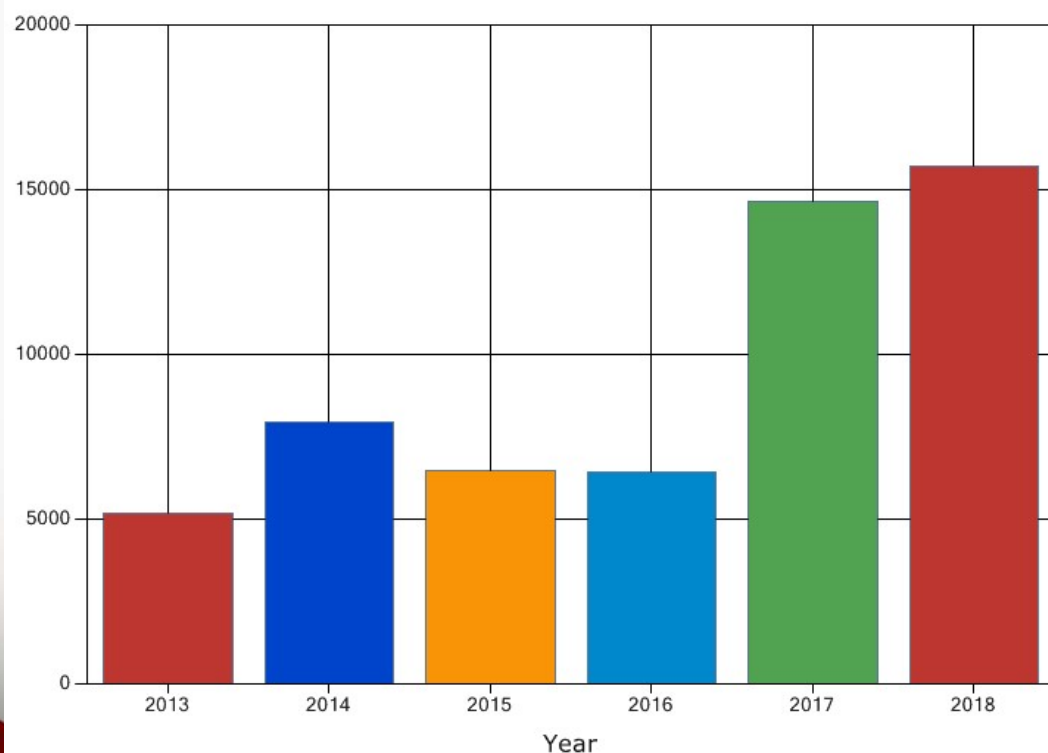
Providenciamos **novas** soluções de segurança ou **Update** constante;

Alteramos as **configurações** de softwares a fim de torná-los mais eficientes e menos suscetíveis a ataques;

Vulnerabilidades

Vulnerabilidades encontradas são publicadas por organizações como NIST e <https://web.nvd.nist.gov/view/vuln/statistics>

Total Matches By Year



Year	Matches
2013	5,187
2014	7,937
2015	6,487
2016	6,447
2017	14,649
2018	15,705

Report Vulnerabilidades

Boletim de Segurança da Microsoft MS17-010 – Crítico

Atualização de segurança para o Microsoft Windows SMB Server (4013389)

Publicado em: 14 de março de 2017

Versão: 1.0

Resumo executivo

Esta atualização de segurança elimina vulnerabilidades no Microsoft Windows. A mais grave das vulnerabilidades poderá permitir a execução remota de código se um invasor enviar mensagens especialmente criadas para um servidor Windows SMBv1.

Esta atualização de segurança foi classificada como Crítica para todas as versões com suporte do Microsoft Windows. Para obter mais informações, consulte a seção **Softwares afetados e classificações de gravidade da vulnerabilidade**.

A atualização de segurança resolve as vulnerabilidades, corrigindo a maneira como o SMBv1 lida com solicitações especialmente criadas.

- [CONFIRM:https://portal.msrc.microsoft.com/en-US/security-guidance/advisory/CVE-2017-0144](https://portal.msrc.microsoft.com/en-US/security-guidance/advisory/CVE-2017-0144)
- BID:96704
- [URL:http://www.securityfocus.com/bid/96704](http://www.securityfocus.com/bid/96704)
- SECTrack:1037991
- [URL:http://www.securitytracker.com/id/1037991](http://www.securitytracker.com/id/1037991)

Nesta página

Sinopse

Softwares afetados e classificações de gravidade da vulnerabilidade

Informações sobre a vulnerabilidade

Implantação de Atualização de Segurança

Windows 8.1; Windows Server
; remote attackers to execute
s different from those described

; not intended to be complete.

Ferramentas de Análise de Vulnerabilidades



Nikto



NMAP + Vulnerabilidades

NMAP tem vários scripts que podem realizar o scan de vulnerabilidades

Alguns deles são:

nmap-vulners e vulscan

Após a instalação do NMAP, os dois scripts podem ser obtidos com o comando:

- `git clone https://github.com/vulnersCom/nmap-vulners.git`
- `git clone https://github.com/scipag/vulscan.git`

OBS: Realize o download dentro do diretório `/usr/share/nmap/scripts`

```
root@debian:/etc/apt# apt-get install git
Lendo listas de pacotes... Pronto
Construindo árvore de dependências
Lendo informação de estado... Pronto
The following additional packages will be installed:
  git-man liberror-perl patch
Pacotes sugeridos:
  git-daemon-run | git-daemon-sysvinit git-doc git-el git-email git-gui gitk gitweb git-cvs
  git-mediawiki git-svn ed diffutils-doc
Os NOVOS pacotes a seguir serão instalados:
  git git-man liberror-perl patch
0 pacotes atualizados, 4 pacotes novos instalados, 0 a serem removidos e 0 não atualizados.
É preciso baixar 7.398 kB de arquivos.
Depois desta operação, 38,2 MB adicionais de espaço em disco serão usados.
Você quer continuar? [S/n] s
```

Pode ser necessário instalar o git para realizar o download.

```
root@debian:/usr/share/nmap/scripts# git clone https://github.com/vulnersCom/nmap-vulners.git
Cloning into 'nmap-vulners'...
remote: Enumerating objects: 14, done.
remote: Counting objects: 100% (14/14), done.
remote: Compressing objects: 100% (12/12), done.
remote: Total 58 (delta 2), reused 12 (delta 2), pack-reused 44
Unpacking objects: 100% (58/58), done.
root@debian:/usr/share/nmap/scripts# git clone https://github.com/scipag/vulscan.git
Cloning into 'vulscan'...
remote: Enumerating objects: 14, done.
remote: Counting objects: 100% (14/14), done.
remote: Compressing objects: 100% (10/10), done.
remote: Total 264 (delta 6), reused 12 (delta 4), pack-reused 250
Receiving objects: 100% (264/264), 16.09 MiB | 349.00 KiB/s, done.
Resolving deltas: 100% (160/160), done.
root@debian:/usr/share/nmap/scripts# _
```

NMAP + Vulnerabilidades

Vulscan

nmap --script vulscan -sV 192.168.0.1

O vulscan utiliza bancos de dados pré-configurados que são armazenados localmente. Podemos ver esses bancos de dados na raiz do diretório vulscan. Execute o comando **ls** abaixo para listar os bancos de dados disponíveis.

ls vulscan/*.csv

vulscan/cve.csv
vulscan/exploitsdb.csv
vulscan/openvas.csv
vulscan/osvdb.csv
vulscan/scipvuldb.csv
vulscan/securityfocus.csv
vulscan/securitytracker.csv
vulscan/xforce.csv

NMAP + Vulnerabilidades

Vulscan

```
nmap --script vulscan --script-args vulscandb=cve.csv -sV 192.168.0.1
```

Para ter um resultado mais “limpo” podemos executar o scan baseado em um determinado banco de dados.

```
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| vulscan: cve.csv:
| [CVE-2011-0762] The vsf_filename_passes_filter function in ls.c in vsftpd before 2.3.3 allows remote authenticated users to cause a denial of service (CPU consumption and process slot exhaustion) via a crafted glob expressions in STAT commands in multiple FTP sessions, a different vulnerability than CVE-2010-2632.
|
|_
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| vulscan: cve.csv:
| [CVE-2010-4755] The (1) remote_glob function in sftp-glob.c and the (2) process_put function in sftp.c in OpenSSH 5.8 and earlier, as used in FreeBSD 7.3 and 8.1, NetBSD 5.0.2, OpenBSD 4.7, and other products, allow remote authenticated users to cause a denial of service (CPU and memory consumption) via crafted glob expressions that do not match any pathnames, as demonstrated by glob expressions in SSH_FXP_STAT requests to an sftp daemon, a different vulnerability than CVE-2010-2632.
| [CVE-2007-4752] ssh in OpenSSH before 4.7 does not properly handle when an untrusted cookie cannot be created and uses a trusted X11 cookie instead, which allows attackers to violate intended policy and gain privileges by causing an X client to be treated as trusted.
| [CVE-2009-2904] A certain Red Hat modification to the ChrootDirectory feature in OpenSSH 4.8, as used in sshd in OpenSSH 4.3 in Red Hat Enterprise Linux (RHEL) 5.4 and Fedora 11, allows local users to gain privileges via hard links to setuid programs that use configuration files within the chroot directory, related to requirements for directory ownership.
```

NMAP + Vulnerabilidades

`nmap --script nmap-vulners -sV 192.168.0.1`

Também será necessário executar o atualizador de vulnerabilidades, com os comandos:

- `cd vulscan/utilities/updater/`
- `chmod +x updateFiles.sh`
- `./updateFiles.sh`

NMAP + Vulnerabilidades

nmap --script vuln 192.169.0.1

O comando vuln, executa “todos” os scripts de vulnerabilidade do NMAP contra o alvo especificado.

```
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs: CVE:CVE-2011-2523 OSVDB:73573
|         vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|         http://osvdb.org/73573
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_
234_backdoor.rb
|_ sslv2-drown:
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| smtp-vuln-cve2010-4344:
|_ The SMTP server is not Exim: NOT VULNERABLE
| ssl-dh-params:
|   VULNERABLE:
|     Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|       State: VULNERABLE
|       Transport Layer Security (TLS) requires that the anonymous
```

NMAP e WIRESHARK para Segurança da Informação

Aula 19: Introdução Sniffer de Rede

Wireshark

A grande maioria dos problemas em uma rede são detectados a nível dos pacotes

Os pacotes de rede revelam problemas de implementação e mostram protocolos sendo usados de maneira maliciosa.

Para melhor compreender e resolver problemas em uma rede, nós vamos ao nível de análise de pacotes.

O que é Análise de Pacotes?

É o processo de capturar e interpretar dados.

A análise de pacotes podem nos ajudar a entender características da rede, quais dispositivos conectados, identificar possíveis ataques ou atividades maliciosas, e encontrar aplicações inseguras.

Alguns programas de análise de pacotes são **tcpdump** e **Wireshark**

Capturing from Wi-Fi

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
81	4.626706	162.144.34.172	192.168.2.105	TCP	66	443 → 52831 [ACK] Seq=1 Ack=2 Win=141 Len=0 SLE=1 SRE=2
82	4.634562	162.144.34.172	192.168.2.105	TCP	66	443 → 52836 [ACK] Seq=1 Ack=2 Win=141 Len=0 SLE=1 SRE=2
83	4.774014	192.168.2.105	162.144.34.172	SSL	55	Continuation Data
84	4.858322	192.168.2.105	23.216.186.153	TCP	55	52663 → 80 [ACK] Seq=1 Ack=1 Win=59 Len=1
85	4.871328	23.216.186.153	192.168.2.105	TCP	66	80 → 52663 [ACK] Seq=1 Ack=2 Win=946 Len=0 SLE=1 SRE=2
86	4.873861	192.168.2.105	23.216.186.153	TCP	55	52664 → 80 [ACK] Seq=1 Ack=1 Win=64 Len=1
87	4.874018	192.168.2.105	23.216.186.153	TCP	55	52662 → 80 [ACK] Seq=1 Ack=1 Win=64 Len=1
88	4.887281	23.216.186.153	192.168.2.105	TCP	66	80 → 52662 [ACK] Seq=1 Ack=2 Win=946 Len=0 SLE=1 SRE=2
89	4.888425	23.216.186.153	192.168.2.105	TCP	66	80 → 52664 [ACK] Seq=1 Ack=2 Win=946 Len=0 SLE=1 SRE=2
90	4.889501	192.168.2.105	23.216.186.153	TCP	55	52661 → 80 [ACK] Seq=1 Ack=1 Win=62 Len=1
91	4.903859	23.216.186.153	192.168.2.105	TCP	66	80 → 52661 [ACK] Seq=1 Ack=2 Win=946 Len=0 SLE=1 SRE=2
92	4.978473	162.144.34.172	192.168.2.105	TCP	66	443 → 52833 [ACK] Seq=1 Ack=2 Win=141 Len=0 SLE=1 SRE=2
93	5.037101	192.168.2.105	151.101.93.168	TLSv1.2	100	Application Data
94	5.037284	192.168.2.105	204.79.197.200	TLSv1.2	100	Application Data
95	5.052293	204.79.197.200	192.168.2.105	TCP	60	443 → 52608 [ACK] Seq=1 Ack=47 Win=1022 Len=0
96	5.053900	204.79.197.200	192.168.2.105	TLSv1.2	100	Application Data

> Frame 1: 381 bytes on wire (3048 bits), 381 bytes captured (3048 bits) on interface 0

> Ethernet II, Src: Cisco-Li_be:ab:fc (98:fc:11:be:ab:fc), Dst: IPv4mcast_7f:ff:fa (01:00:5e:7f:ff:fa)

> Internet Protocol Version 4, Src: 192.168.2.1, Dst: 239.255.255.250

> User Datagram Protocol, Src Port: 1900, Dst Port: 1900

> Simple Service Discovery Protocol

```

0000  01 00 5e 7f ff fa 98 fc 11 be ab fc 08 00 45 00  ..^.....E.
0010  01 6f 9c 17 00 00 04 11 66 c3 c0 a8 02 01 ef ff  .o.....f.....
0020  ff fa 07 6c 07 6c 01 5b 6c 65 4e 4f 54 49 46 59  ...l.l.[ leNOTIFY
0030  20 2a 20 48 54 54 50 2f 31 2e 31 0d 0a 48 6f 73  * HTTP/ 1.1..Hos
0040  74 3a 32 33 39 2e 32 35 35 2e 32 35 35 2e 32 35  t:239.25 5.255.25
0050  30 3a 31 39 30 30 0d 0a 4e 54 3a 75 72 6e 3a 73  0:1900.. NT:urn:s
0060  63 68 65 6d 61 73 2d 77 69 66 69 61 6c 6c 69 61  chemas-w ifiallia
0070  6e 63 65 2d 6f 72 67 3a 73 65 72 76 69 63 65 3a  nce-org: service:
0080  57 46 41 57 4c 41 4e 43 6f 6e 66 69 67 3a 31 0d  WFAWLANC onfig:1.
0090  0a 4e 54 53 3a 73 73 64 70 3a 61 6c 69 76 65 0d  .NTS:ssd p:alive.
  
```

O processo de sniffer de pacotes é dividido em três partes:
coleta, **conversão** e **análise**.

Coleta:

O software de sniffer coloca a interface de rede em **modo promíscuo**, podendo **escutar** todo o **tráfego em seu segmento de rede** capturando os dados.

Conversão:

Os dados capturados são convertidos de uma maneira legível.

Análise:

O **analisador de pacotes** pega os dados capturados, verifica o seu protocolo com base nas informações extraídas.

Tráfego de Rede

Podemos considerar o tráfego de rede em três classes:

Broadcast, Multicast e Unicast.

Tráfego Broadcast

Um pacote de broadcast é enviado a todas as portas de um segmento de rede.

Tráfego Multicast

O Multicast é um meio de transmitir um pacote a partir de uma única fonte para múltiplos destinos simultaneamente

Tráfego Unicast

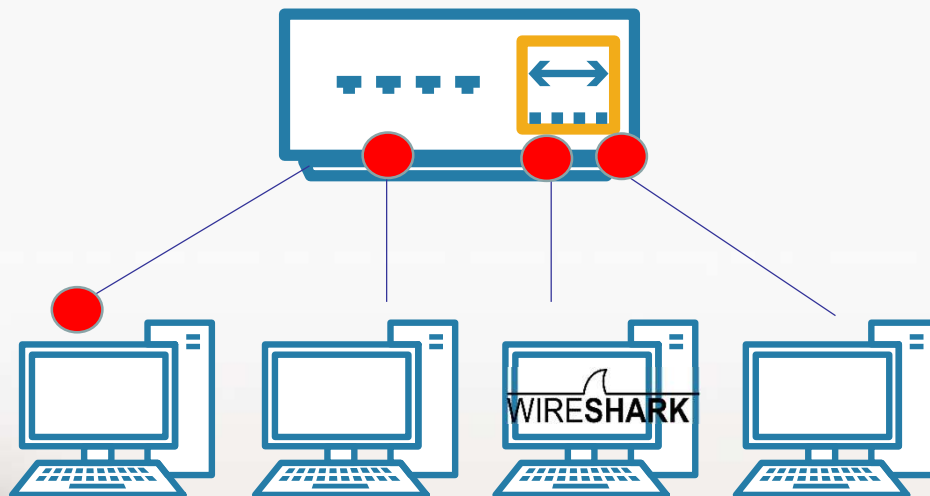
Um pacote unicast é transmitido diretamente de um computador para outro.

É só ligar o Wireshark e sair usando?

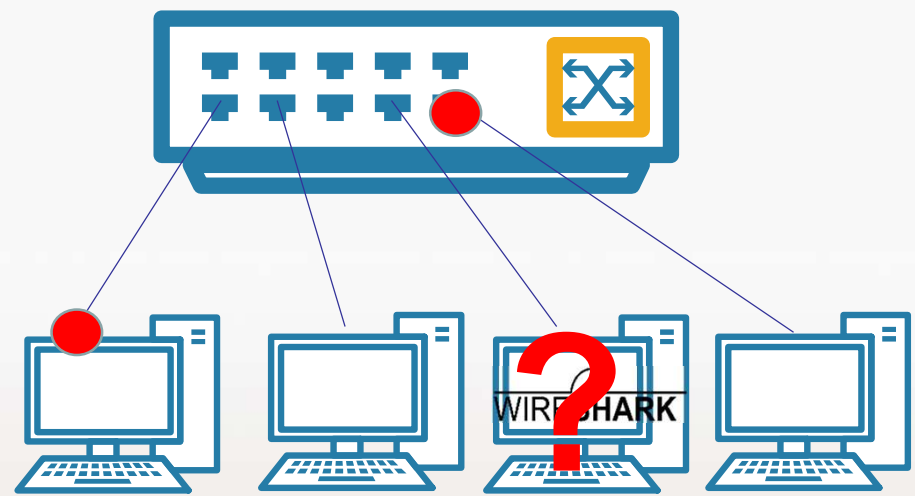
Para entender a localização de um sniffer é necessário voltar e lembrar alguns conceitos de rede

Qual a diferença entre um HUB e um SWITCH?

HUB



Switch



Então com um Switch eu não realizo a captura de pacotes?

Existem três formas principais de capturar o tráfego de um dispositivo em uma rede com switch:

Espelhamento de porta, o envenenamento de cache ARP, e hubbing.

Espelhamento de Porta

Espelhamento de porta (Port mirroring), é a maneira correta de capturar o tráfego de rede através de um switch.

Aqui, o administrador de redes redireciona o tráfego de rede do dispositivo desejado para o Sniffer.

Hubbing

O Hubbing é uma técnica em que você adiciona um HUB no caminho físico do dispositivo o qual você deseja capturar as informações, dessa maneira o HUB irá replicar todas as informações para todas as portas conectadas.

Envenenamento do Cache ARP (ARP spoofing)

Para que o Switch possa entregar o pacote de rede para o destino correto, ele realiza o mapeamento da rede e cria o que chamamos de tabela ARP.

Cada dispositivo novo conectado na rede, passa a integrar essa tabela do Switch.

Quando um computador precisa enviar dados para outro, ele envia uma solicitação ARP pedindo ao o switch onde está ligado.

O switch agora tem a capacidade de estabelecer a comunicação entre esses dispositivos.

Quando um atacante ou farejador que escutar o segmento um segmento da rede, então ele “engana” o switch, alterando a tabela ARP, dizendo que ele é o dispositivo e agora ele passa a receber os dados.

NMAP e WIRESHARK para Segurança da Informação

Aula 20: Wireshark

Sobre o Wireshark

O Wireshark é o analisador de pacotes de rede.

Um analisador de pacotes de rede tentará capturar pacotes e tentar exibir os dados dos pacotes o mais detalhados possíveis.

O desenvolvimento do Wireshark prospera graças às contribuições voluntárias de especialistas em redes ao redor do mundo e é a continuação de um projeto iniciado por Gerald Combs em 1998.

O Wireshark está disponível gratuitamente, é de código aberto e é um dos melhores analisadores de pacotes disponíveis hoje

O **Wireshark** possui um rico conjunto de recursos que inclui o seguinte:

Inspeção profunda de centenas de protocolos, com mais sendo adicionados o tempo todo.

Captura ao vivo e análise off-line.

Multiplataforma: Executa no Windows, Linux, macOS, Solaris, FreeBSD, NetBSD e muitos outros.

Os dados de rede capturados podem ser navegados por uma GUI.

<https://www.wireshark.org/>

Instalação Wireshark

Link para download: <https://www.wireshark.org/#download>

Stable Release (3.2.0) • December 18, 2019	^
 Windows Installer (64-bit) Windows Installer (32-bit) Windows PortableApps® (32-bit) macOS 10.12 and later Intel 64-bit .dmg Source Code	
Old Stable Release (3.0.7) • December 4, 2019	v
Documentation	v

OBS: escolha a versão compatível ao seu sistema operacional

Instalando o Wireshark

NMAP e WIRESHARK para Segurança da Informação

Aula 21: Wireshark: Interface, Filtros e Coletas

Menu de Comandos

Filtro Expressão

Lista de Pacotes Capturados

Detalhes do pacote selecionado

Informações em HEXADECIMAL e ASCII

The image shows the Wireshark network protocol analyzer interface. The top menu bar includes File, Edit, View, Go, Capture, Analyze, Statistics, Telephony, Wireless, Tools, and Help. Below the menu is a toolbar with various icons. A filter bar at the top of the packet list contains the text 'Apply a display filter ... <Ctrl-/>'. The main packet list displays a table of captured packets with columns for No., Time, Source, Destination, Protocol, Length, and Info. The selected packet (No. 1610, Time 10.673638) is highlighted in blue. The details pane on the right shows the structure of the selected packet, including Ethernet II, Internet Protocol Version 4, User Datagram Protocol, and Domain Name System (query). The bottom pane shows the raw data in hexadecimal and ASCII format.

No.	Time	Source	Destination	Protocol	Length	Info
1610...	9.778563	10.1.70.87	172.16.147.161	TCP	55	[TCP Keep-Alive] 1316 → 445
1610...	9.779530	10.1.70.87	172.16.147.161	TCP	55	[TCP Keep-Alive] 13299 → 445
1610...	9.781389	172.16.147.161	10.1.70.87	TCP	66	[TCP Keep-Alive ACK] 445 → 1316
1610...	9.782247	172.16.147.161	10.1.70.87	TCP	66	[TCP Keep-Alive ACK] 445 → 13299
1610...	9.872362	10.1.70.108	224.0.0.251	MDNS	82	Standard query 0x0000 PTR
1610...	9.872552	fe80::9554:23f7:b45...	ff02::fb	MDNS	102	Standard query 0x0000 PTR
1610...	9.898546	10.1.70.62	239.255.255.250	SSDP	175	M-SEARCH * HTTP/1.1
1610...	10.201107	172.20.9.99	10.1.70.87	TLSv1.2	105	Application Data
1610...	10.205675	10.1.60.75	10.1.70.147	TCP	66	[TCP Retransmission] 52553 → 52553
1610...	10.242165	10.1.70.87	172.20.9.99	TCP	54	1312 → 3389 [ACK] Seq=43355
1610...	10.510778	192.168.111.37	10.1.70.50	TCP	66	[TCP Retransmission] 64317 → 64317
1610...	10.608093	10.1.253.119	10.1.70.50	TCP	66	58822 → 7680 [SYN] Seq=0 W
1610...	10.673638	10.1.70.108	239.255.255.250	SSDP	216	M-SEARCH * HTTP/1.1

Frame 6: 80 bytes on wire (640 bits), 80 bytes captured (640 bits) on interface 0

Ethernet II, Src: Digibras_9c:56:92 (64:1c:67:9c:56:92), Dst: Cisco_ff:fd:90 (00:08:e3:ff:fd:90)

Internet Protocol Version 4, Src: 10.1.70.87, Dst: 172.16.147.200

User Datagram Protocol, Src Port: 57164, Dst Port: 53

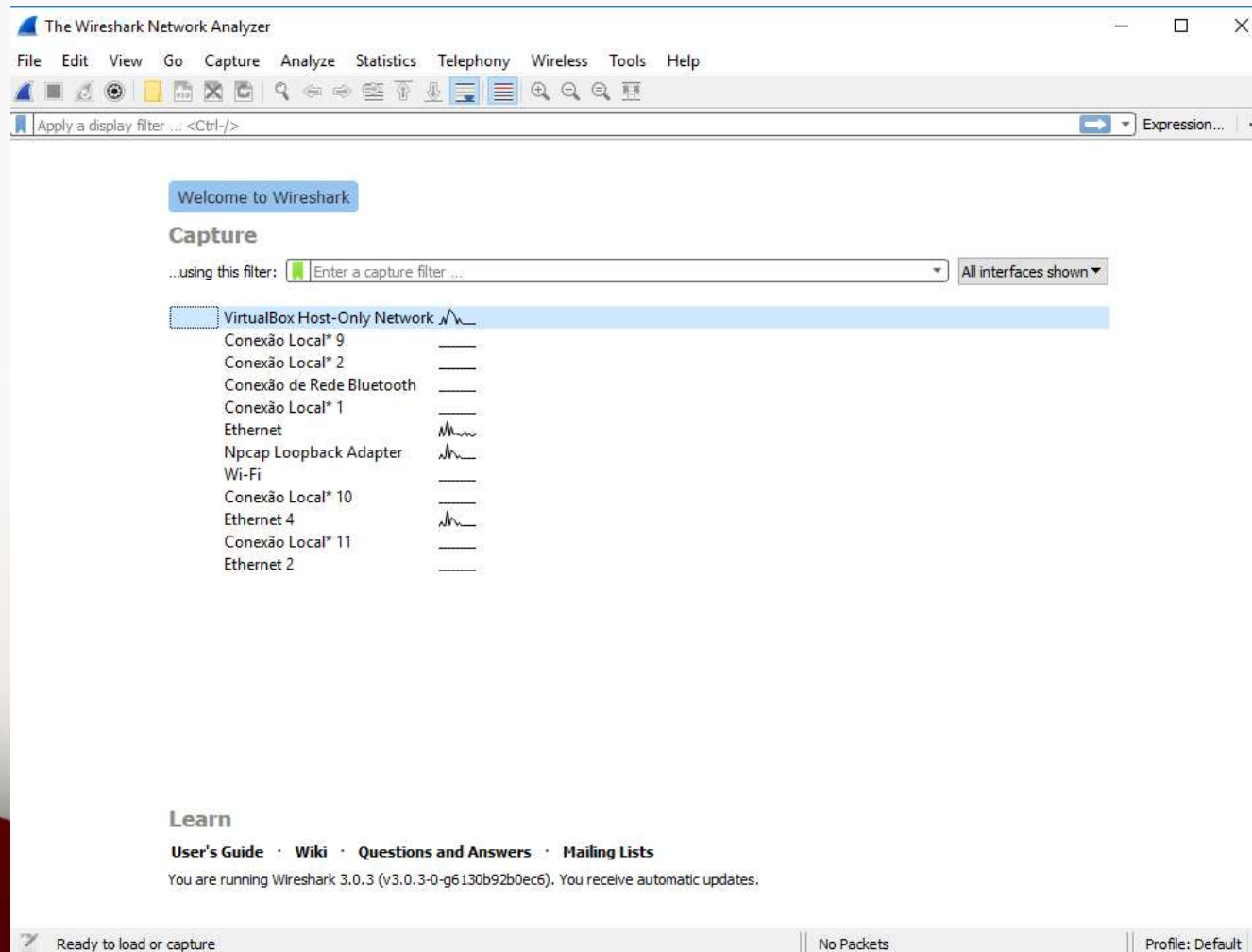
Domain Name System (query)

```

0000  00 08 e3 ff fd 90 64 1c 67 9c 56 92 08 00 45 00  .....d·g·V···E·
0010  00 42 6f 92 00 00 80 11 3a e8 0a 01 46 57 ac 10  ·Bo····:···FW··
0020  93 c8 df 4c 00 35 00 2e 7f f4 9b 4a 01 00 00 01  ...L·5·.···J····
0030  00 00 00 00 00 00 09 45 4d 53 2d 57 49 4e 4e 54  .....E MS-WINNT
0040  03 65 6d 73 03 63 6f 6d 02 62 72 00 00 01 00 01  ·ems·com·br····
    
```

wireshark_Ethernet_20190910152101_a02400.pcapng | Packets: 161081 · Displayed: 161081 (100.0%) | Profile: Default

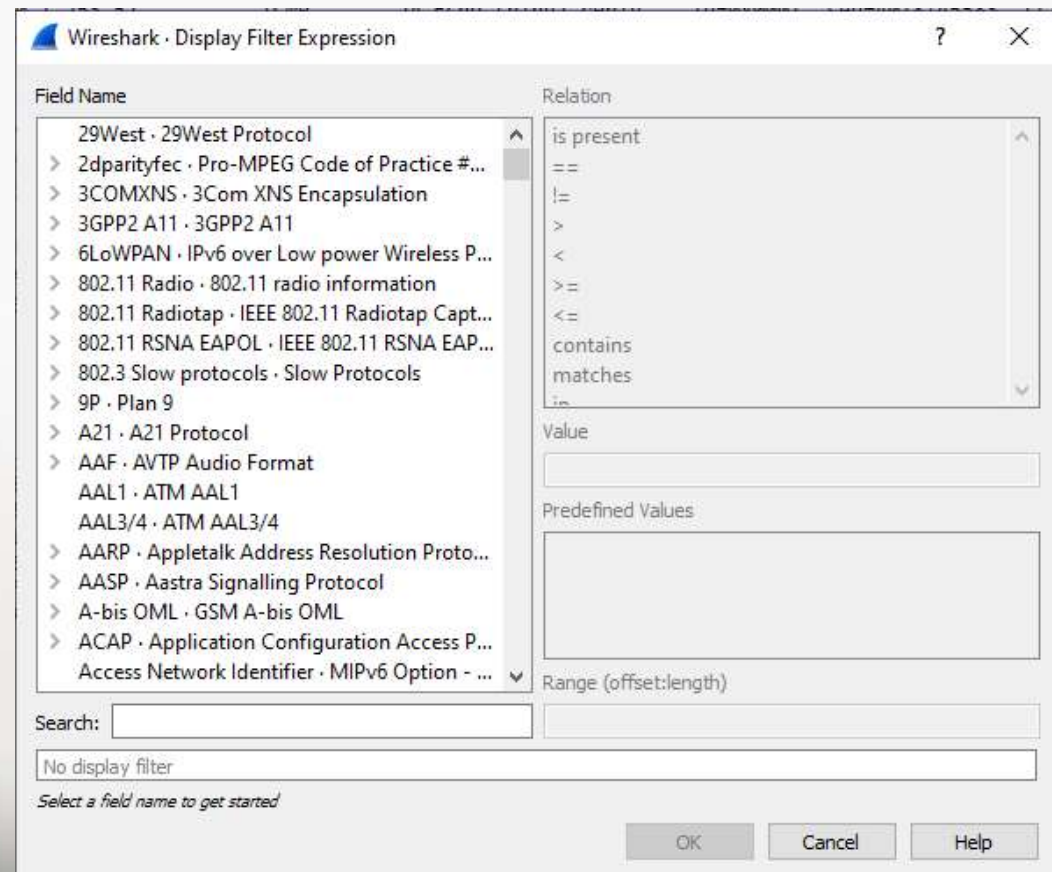
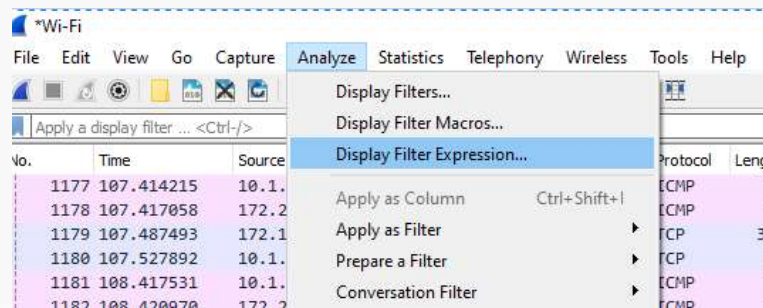
1. Abra o Wireshark.
2. No menu principal, selecione Capture e, em seguida, Options. Será apresentada uma caixa listando as interfaces de rede. Selecione a interface e clique em Start.



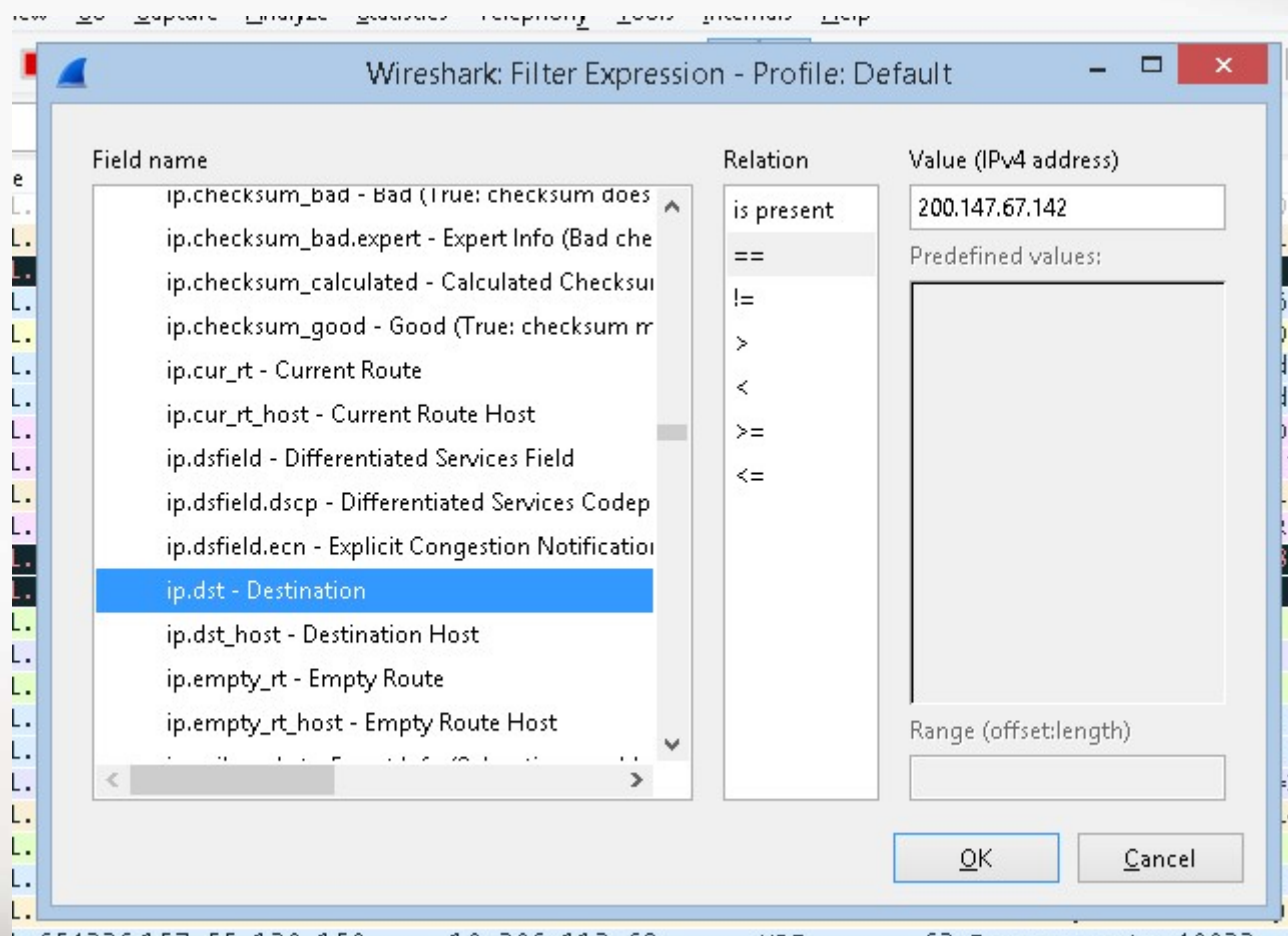
Construtor de Filtros

A caixa de dialogo de construção de filtros é um recurso que torna mais fácil a utilização do Wireshark pelos usuários para capturar e criar filtros de exibição.

Para acessar esta caixa de diálogo, clique no menu **Analyze** e na opção **Display Filter Expression**.

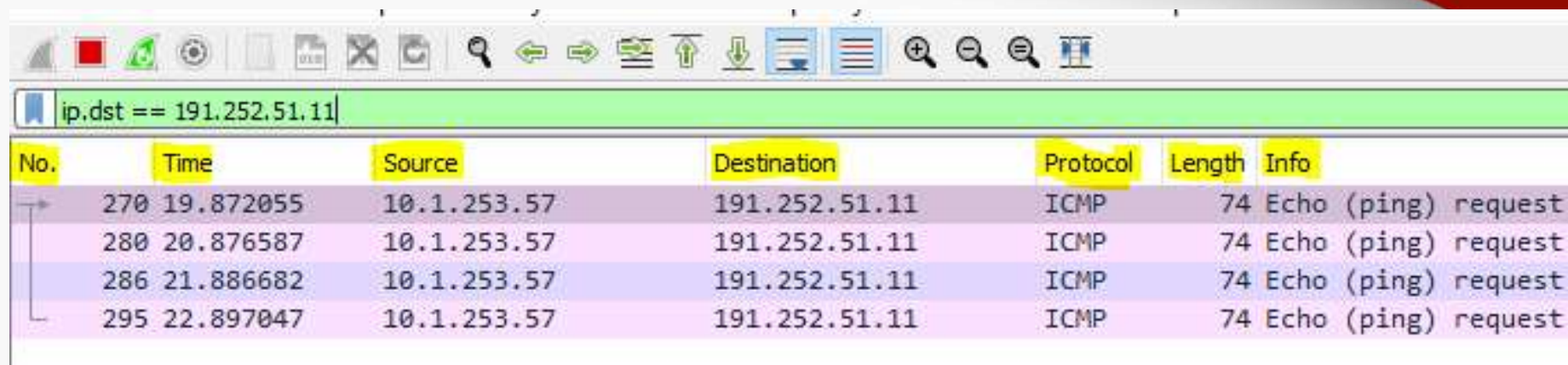


Exemplo: Vamos filtrar os pacotes direcionados ao IP 192.168.0.166



ip.dst == 191.252.51.11 – samsec.com.br

Quais informações encontramos nessa janela?



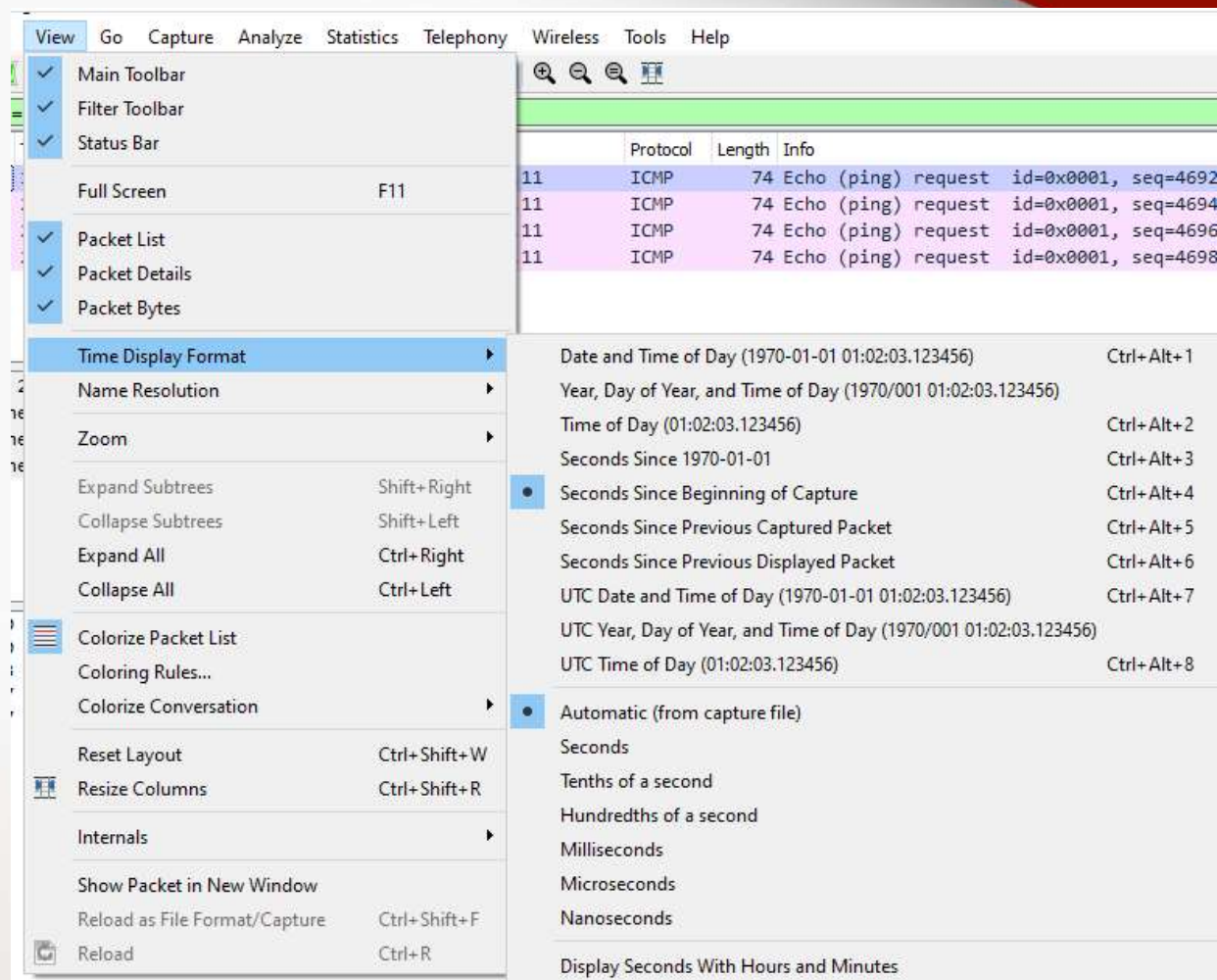
No.	Time	Source	Destination	Protocol	Length	Info
270	19.872055	10.1.253.57	191.252.51.11	ICMP	74	Echo (ping) request
280	20.876587	10.1.253.57	191.252.51.11	ICMP	74	Echo (ping) request
286	21.886682	10.1.253.57	191.252.51.11	ICMP	74	Echo (ping) request
295	22.897047	10.1.253.57	191.252.51.11	ICMP	74	Echo (ping) request

- **No.** - O número do pacote no arquivo de captura. Esse número não será alterado, mesmo que seja usado um filtro de exibição.
- **Time** - O registro de data e hora do pacote. O formato de apresentação deste registro de data e hora pode ser alterado.
- **Source** - O endereço de origem deste pacote.
- **Destination** - O endereço para onde este pacote está indo.
- **Protocol** - O nome do protocolo.
- **Length** - O comprimento de cada pacote.
- **Info** - Informações adicionais sobre o conteúdo do pacote.

Data e Hora do pacote

Por padrão a data e a hora dos pacotes capturados, são exibidos a partir do início da captura.

Pode ser alterado esse formato para outros padrões.



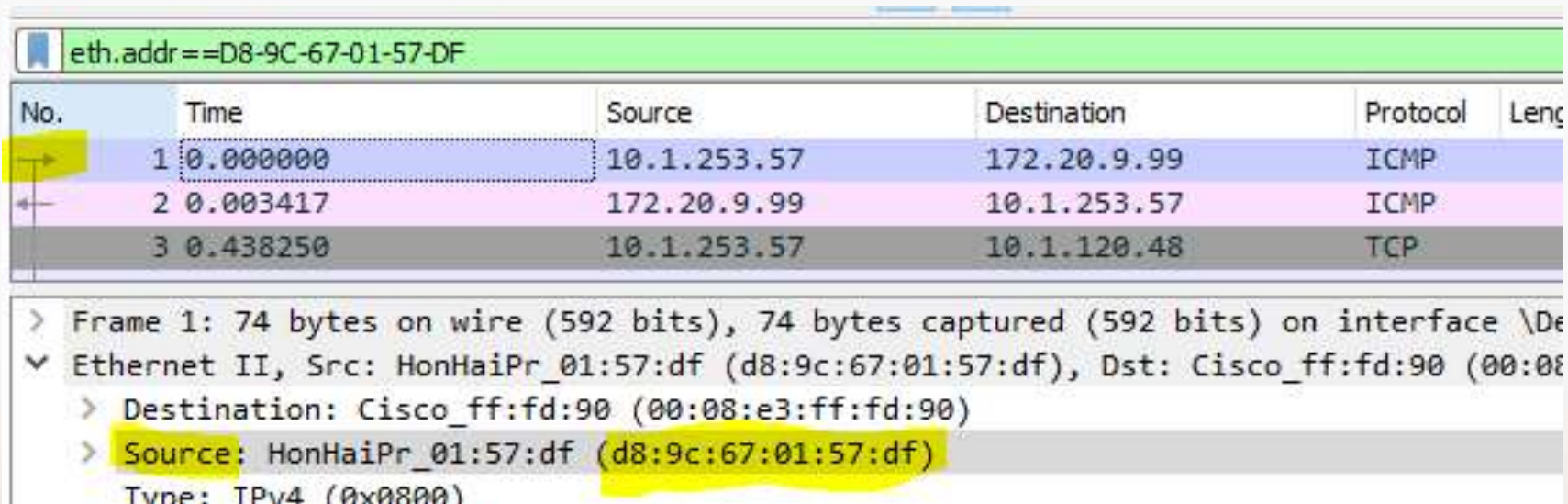
NMAP e WIRESHARK para Segurança da Informação

Aula 22: Wireshark: Expressões Parte 1

Expressões Wireshark

Filtrando por Mac Address

Todos os quadros Ethernet que contêm o endereço físico 00:22:64:7e:1a:3a:
eth.addr==D8-9C-67-01-57-DF



The image shows a Wireshark interface with a filter 'eth.addr==D8-9C-67-01-57-DF' applied to the packet list pane. The packet list shows three packets, with the first packet selected. The packet details pane shows the Ethernet II header for the selected packet, with the source MAC address highlighted in yellow.

No.	Time	Source	Destination	Protocol	Length
1	0.000000	10.1.253.57	172.20.9.99	ICMP	
2	0.003417	172.20.9.99	10.1.253.57	ICMP	
3	0.438250	10.1.253.57	10.1.120.48	TCP	

> Frame 1: 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on interface \Device\NPF...
▼ Ethernet II, Src: HonHaiPr_01:57:df (d8:9c:67:01:57:df), Dst: Cisco_ff:fd:90 (00:08:e3:ff:fd:90)
 > Destination: Cisco_ff:fd:90 (00:08:e3:ff:fd:90)
 > Source: HonHaiPr_01:57:df (d8:9c:67:01:57:df)
 Type: IPv4 (0x0800)

Expressões Wireshark

Filtrando por Mac Address

Todos os quadros Ethernet que contenham o endereço físico 00:22:64:7e:1a:3a **como origem:**

`eth.src== D8-9C-67-01-57-DF`

eth.src== D8-9C-67-01-57-DF					
No.	Time	Source	Destination	Protocol	Length
312	24.918565	10.1.253.57	172.16.45.115	HTTP	308
> Frame 312: 308 bytes on wire (2464 bits), 308 bytes captured (2464 bits) on interface ▼ Ethernet II, Src: HonHaiPr_01:57:df (d8:9c:67:01:57:df), Dst: Cisco_ff:fd:90 (00:08:e3:ff:fd:90) > Destination: Cisco_ff:fd:90 (00:08:e3:ff:fd:90) > Source: HonHaiPr_01:57:df (d8:9c:67:01:57:df)					

Expressões Wireshark

Filtrando por Mac Address

Todos os quadros Ethernet que contenham o endereço físico ff:ff:ff:ff:ff:ff **como destino:**
eth.dst== D8-9C-67-01-57-DF

eth.dst== D8-9C-67-01-57-DF						
No.	Time	Source	Destination	Protocol	Length	Info
266	25.519407	172.16.45.115	10.1.253.57	TCP	60	8080 → 1052
> Frame 266: 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface \Device\NPF_{1F4...}						
▼ Ethernet II, Src: Cisco_ff:fd:90 (00:08:e3:ff:fd:90), Dst: HonHaiPr_01:57:df (d8:9c:67:01:57:df)						
> Destination: HonHaiPr_01:57:df (d8:9c:67:01:57:df)						
> Source: Cisco_ff:fd:90 (00:08:e3:ff:fd:90)						

Expressões Wireshark

Filtrando por Protocolo

Pacotes TCP com a porta 80:
tcp.port==80

tcp.port == 80						
No.	Time	Source	Destination	Protocol	Length	Info
269	25.560550	10.1.253.57	192.168.0.10	TCP	66	1064 → 80
> Frame 269: 66 bytes on wire (528 bits), 66 bytes captured (528 bits) on interface \Device\NPF_{1 > Ethernet II, Src: HonHaiPr_01:57:df (d8:9c:67:01:57:df), Dst: Cisco_ff:fd:90 (00:08:e3:ff:fd:90) > Internet Protocol Version 4, Src: 10.1.253.57, Dst: 192.168.0.10 ✓ Transmission Control Protocol, Src Port: 1064, Dst Port: 80, Seq: 0, Len: 0 Source Port: 1064 Destination Port: 80						

Expressões Wireshark

Filtrando por Protocolo

Pacotes TCP com a porta de destino 23:

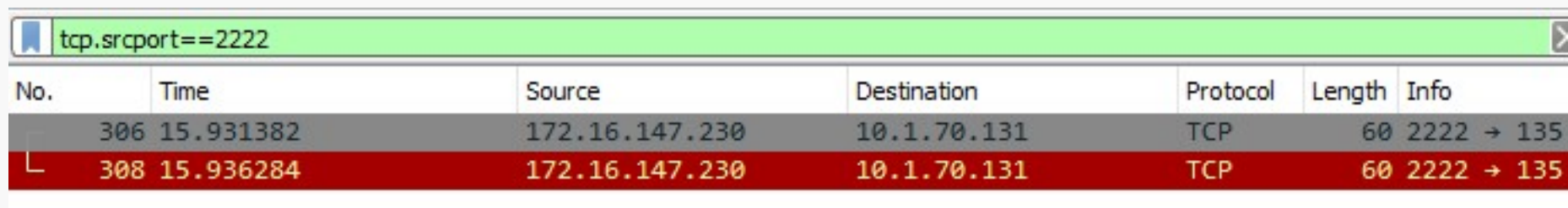
`tcp.dstport==23`

tcp.dstport==23						
No.	Time	Source	Destination	Protocol	Length	Info
1053	31.544143	172.16.147.230	10.1.70.131	TCP	60	58042 → 135
L 1055	31.549481	172.16.147.230	10.1.70.131	TCP	60	58042 → 135

Expressões Wireshark

Filtrando por Protocolo

Pacotes TCP com a porta de origem 2222;
tcp.srcport==2222



The screenshot shows the Wireshark interface with a filter bar at the top containing the expression 'tcp.srcport==2222'. Below the filter bar, a table of captured packets is displayed, showing only two packets that match the filter. The first packet is highlighted in grey, and the second is highlighted in red. Both packets are TCP segments from source port 2222 to destination port 135.

No.	Time	Source	Destination	Protocol	Length	Info
306	15.931382	172.16.147.230	10.1.70.131	TCP	60	2222 → 135
308	15.936284	172.16.147.230	10.1.70.131	TCP	60	2222 → 135

Expressões Wireshark

Filtrando por Protocolo

Verificar conexões via http

ip.addr == 10.206.112.69 && http

NMAP e WIRESHARK para Segurança da Informação

Aula 23: Wireshark: Expressões Parte 2

Expressões Wireshark

Filtrando por Protocolo

Verificar conexões via http que não seja o ip marcado.

ip.addr != 10.206.112.69 && http

Expressões Wireshark

Filtrando por Protocolo

Verificar a saída de ICMP

ip.src == 10.206.112.69 && icmp

ip.src == 172.16.147.230 && icmp				
No.	Time	Source	Destination	Protocol
752	18.595059	172.16.147.230	10.1.70.131	ICMP
789	19.600262	172.16.147.230	10.1.70.131	ICMP
871	20.605126	172.16.147.230	10.1.70.131	ICMP
915	21.615316	172.16.147.230	10.1.70.131	ICMP

Expressões Wireshark

Filtrando por Protocolo
 Verifica qualquer pacote de ICMP
ip.src && icmp

ip.src && icmp					
No.	Time	Source	Destination	Protocol	
334	13.164057	10.1.70.131	172.16.147.231	ICMP	
335	13.171894	10.1.70.131	172.16.147.230	ICMP	
336	13.172751	172.16.147.231	10.1.70.131	ICMP	
337	13.175058	172.16.147.230	10.1.70.131	ICMP	
353	14.177557	10.1.70.131	172.16.147.231	ICMP	
354	14.185039	10.1.70.131	172.16.147.230	ICMP	
355	14.186113	172.16.147.231	10.1.70.131	ICMP	

Expressões Wireshark

Filtrando por Protocolo

Verifica tudo relacionado ao uol.com.br.

tcp contains "uol.com.br"

tcp contains "uol.com.br"						
No.	Time	Source	Destination	Protocol	Length	Info
3095...	354.578729	192.168.0.181	200.147.3.157	HTTP	804	GET / HTTP/1.1
3095...	354.594398	200.147.3.157	192.168.0.181	HTTP	169	HTTP/1.0 302 Found
3095...	354.684627	192.168.0.181	13.33.135.103	TLSv1.2	571	Client Hello
3095...	354.707214	13.33.135.103	192.168.0.181	TLSv1.2	1514	Server Hello
3097...	355.456786	192.168.0.181	99.84.28.54	TLSv1.2	571	Client Hello
3097...	355.485833	99.84.28.54	192.168.0.181	TLSv1.2	1514	Server Hello
3102...	357.024116	192.168.0.181	200.147.160.22	TLSv1.2	571	Client Hello
3102...	357.042564	200.147.160.22	192.168.0.181	TLSv1.2	1514	Server Hello
3103...	357.105493	192.168.0.181	200.147.99.186	TLSv1.2	571	Client Hello
3103...	357.126479	200.147.99.186	192.168.0.181	TLSv1.2	1514	Server Hello
3103...	357.127446	200.147.99.186	192.168.0.181	TCP	1514	443 → 51783 [ACK] Seq=
3108...	358.432384	192.168.0.181	186.234.36.14	TLSv1.2	571	Client Hello
3108...	358.453346	186.234.36.14	192.168.0.181	TLSv1.2	1514	Server Hello

Expressões Wireshark

Filtrando por Protocolo

Verifica o acesso aos dois endereços de destino.

ip.dst == 200.221.2.45 or ip.dst == 186.192.90.5

ip.dst == 192.168.0.1 or ip.dst == 192.168.0.122						
No.	Time	Source	Destination	Protocol	Length	Info
37	5.601015	192.168.0.181	192.168.0.1	DNS	74	Standard query 0x85a4 A www.uol.com.br
68	5.623088	192.168.0.181	192.168.0.1	DNS	81	Standard query 0xf4ab A conteudo.jsuol.com.br
71	5.624330	192.168.0.181	192.168.0.1	DNS	71	Standard query 0x1052 A stc.uol.com
256	5.873053	192.168.0.181	192.168.0.1	DNS	73	Standard query 0xd005 A tm.uol.com.br
1159	25.427909	192.168.0.181	192.168.0.122	ICMP	74	Echo (ping) request id=0x0001, seq=13/3328, tt
1167	26.431779	192.168.0.181	192.168.0.122	ICMP	74	Echo (ping) request id=0x0001, seq=14/3584, tt
1169	27.435862	192.168.0.181	192.168.0.122	ICMP	74	Echo (ping) request id=0x0001, seq=15/3840, tt
1171	28.440580	192.168.0.181	192.168.0.122	ICMP	74	Echo (ping) request id=0x0001, seq=16/4096, tt

Expressões Wireshark

Pacotes TCP maiores ou iguais a 100 Bytes:

`tcp.len >= 100`

tcp.len >= 100					
No.	Time	Source	Destination	Protocol	Length
55	1.971523	172.16.45.115	10.1.70.131	TCP	576
325	12.965474	172.16.45.115	10.1.70.131	TCP	576
378	16.140618	172.16.45.115	10.1.70.131	TCP	186
379	16.154607	10.1.70.131	172.16.45.115	TCP	342
439	17.311487	172.16.45.115	10.1.70.131	TCP	308
665	28.559050	172.16.45.115	10.1.70.131	TCP	646
668	28.581219	10.1.70.131	172.16.45.115	TCP	745
675	29.037346	172.16.45.115	10.1.70.131	TCP	314
870	36.582275	172.16.45.115	10.1.70.131	TCP	576

Expressões Wireshark

Pacotes TCP com a flag SYN ativada:
tcp.flags.syn==1

tcp.flags.syn==1						
No.	Time	Source	Destination	Protocol	Length	Info
24	0.457769	10.1.60.240	10.1.70.127	TCP	66	57099 → 7680 [SYN]
49	1.484914	10.1.121.58	10.1.70.125	TCP	66	54273 → 7680 [SYN]
93	2.799868	10.1.90.79	10.1.70.127	TCP	66	61483 → 7680 [SYN]
106	3.326235	10.3.90.55	10.1.70.128	TCP	66	55219 → 7680 [SYN]
116	3.948950	10.1.121.207	10.1.70.127	TCP	66	61415 → 7680 [SYN]
129	4.615555	10.1.70.131	10.7.60.88	TCP	66	17509 → 7680 [SYN]
130	4.617597	10.1.70.131	10.7.60.107	TCP	66	17510 → 7680 [SYN]
131	4.619636	10.1.70.131	10.1.122.83	TCP	66	17511 → 7680 [SYN]
132	4.642313	10.7.60.88	10.1.70.131	TCP	66	7680 → 17509 [SYN]
135	4.652046	10.7.60.107	10.1.70.131	TCP	66	7680 → 17510 [SYN]

Expressões Wireshark

Pacotes TCP com a flag SYN ativada e a flag ACK desativada:
`tcp.flags.syn==1 and tcp.flags.ack==0`

tcp.flags.syn==1 and tcp.flags.ack==0						
No.	Time	Source	Destination	Protocol	Length	Info
24	0.457769	10.1.60.240	10.1.70.127	TCP	66	57099 → 7680 [SYN]
49	1.484914	10.1.121.58	10.1.70.125	TCP	66	54273 → 7680 [SYN]
93	2.799868	10.1.90.79	10.1.70.127	TCP	66	61483 → 7680 [SYN]
106	3.326235	10.3.90.55	10.1.70.128	TCP	66	55219 → 7680 [SYN]
116	3.948950	10.1.121.207	10.1.70.127	TCP	66	61415 → 7680 [SYN]
129	4.615555	10.1.70.131	10.7.60.88	TCP	66	17509 → 7680 [SYN]
130	4.617597	10.1.70.131	10.7.60.107	TCP	66	17510 → 7680 [SYN]
131	4.619636	10.1.70.131	10.1.122.83	TCP	66	17511 → 7680 [SYN]

Expressões Wireshark

Pacotes TCP com a flag RESET ativada:

`tcp.flags.reset == 1`

tcp.flags.reset == 1						
No.	Time	Source	Destination	Protocol	Length	Info
3329...	4373.759229	10.1.70.131	172.16.147.45	TCP	54	1677 → 53181 [RST, ACK]
3336...	4398.651799	10.1.70.131	172.16.147.201	TCP	54	1688 → 445 [RST, ACK] Se
3341...	4414.910674	10.1.70.131	172.16.147.45	TCP	54	1690 → 445 [RST, ACK] Se
3344...	4423.745679	10.1.70.131	172.16.147.45	TCP	54	1667 → 53181 [RST, ACK]
3344...	4423.745822	10.1.70.131	172.16.147.45	TCP	54	1661 → 53181 [RST, ACK]
3362...	4474.920619	10.1.70.131	172.16.147.45	TCP	54	1708 → 445 [RST, ACK] Se
3363...	4478.745389	10.1.70.131	172.16.147.45	TCP	54	1709 → 53181 [RST, ACK]
3380...	4504.902551	10.1.70.131	172.16.147.45	TCP	54	1727 → 445 [RST, ACK] Se
3385...	4517.510720	10.1.70.131	172.16.147.45	TCP	54	1739 → 445 [RST, ACK] Se

Operadores

Igual: eq ou ==
Não igual: ne ou !=
Maior que: gt or >
Menor que: lt or <
Maior ou igual: ge ou >=
Menor ou igual: le ou <=
E lógico: and ou &&
Ou lógico: or ou ||
Ou exclusivo: xor or ^^
Não lógico (negação): not ou !

NMAP e WIRESHARK para Segurança da Informação

Aula 24: Wireshark: SMB

Filtrando arquivos SMB

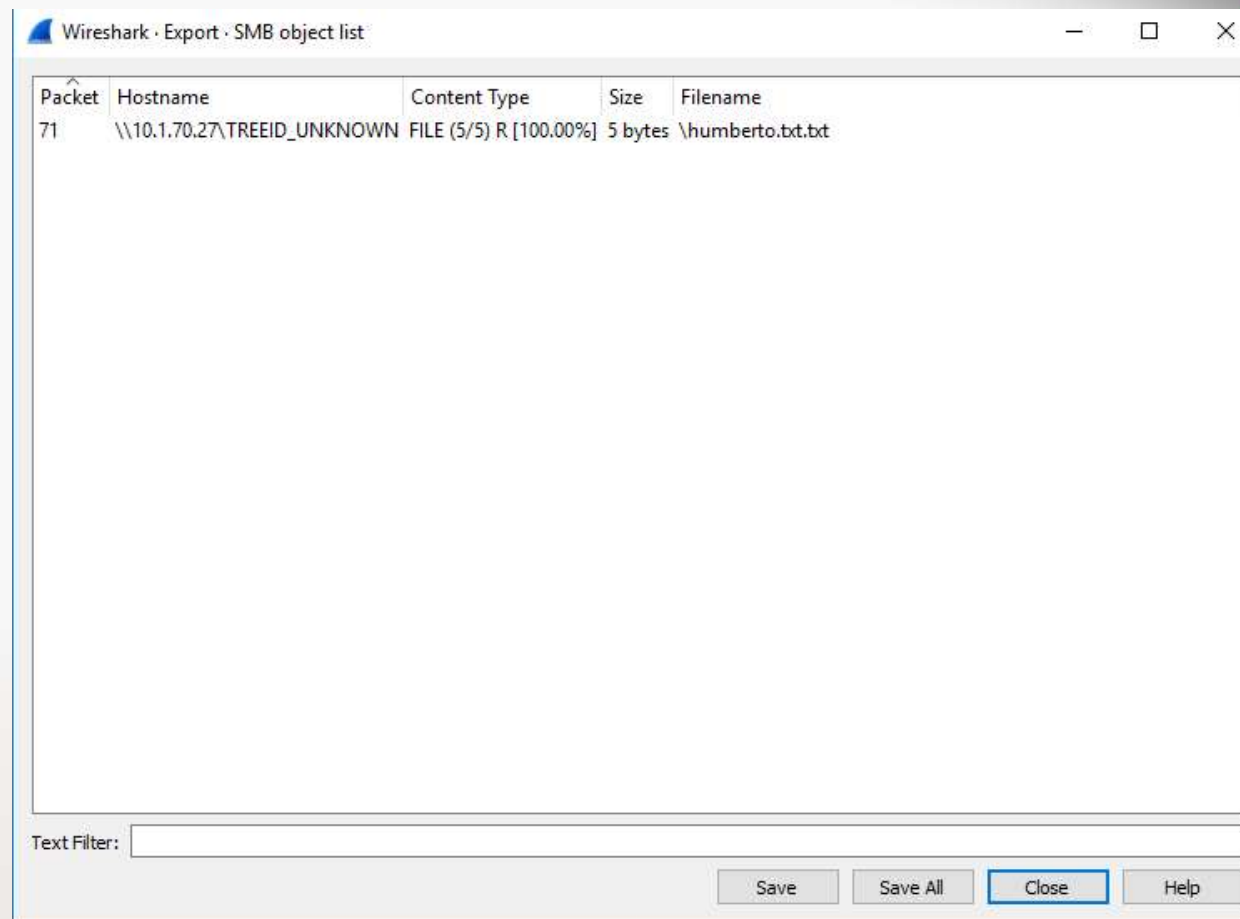
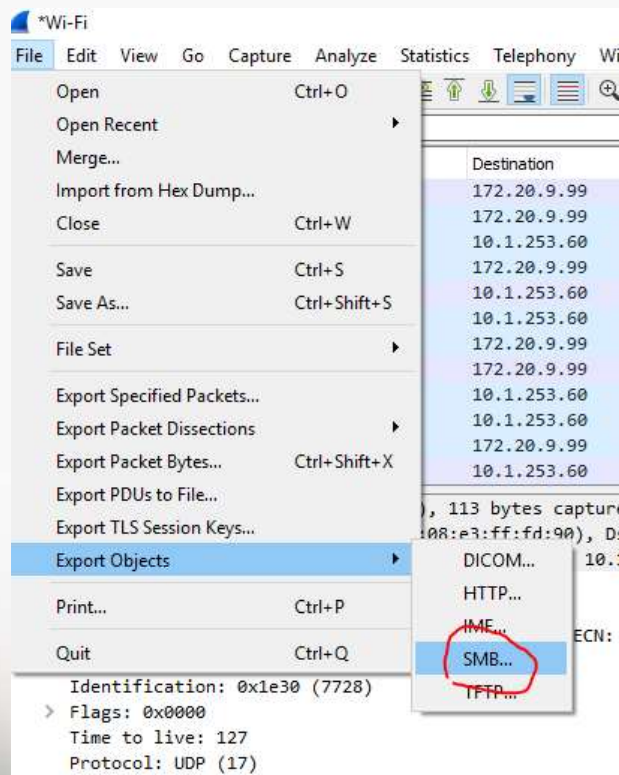
smb2 && ip.dst==10.1.70.27

Filter: smb2 && ip.dst == 10.1.70.27

No.	Time	Source	Destination	Protocol	Length	Info
79	5.234107	10.1.253.60	10.1.70.27	SMB2	146	Close Request File: humberto.txt.txt
81	5.244673	10.1.253.60	10.1.70.27	SMB2	354	Create Request File: humberto.txt.txt
84	5.328324	10.1.253.60	10.1.70.27	SMB2	370	GetInfo Request FILE_INFO/SMB2_FILE_EA_INFO File: humberto.txt.txt;GetInfo Request FILE_INFO/SMB2_FILE_STRE...
86	5.333917	10.1.253.60	10.1.70.27	SMB2	146	Close Request File: humberto.txt.txt
90	5.376865	10.1.253.60	10.1.70.27	SMB2	354	Create Request File: humberto.txt.txt
92	5.380080	10.1.253.60	10.1.70.27	SMB2	370	GetInfo Request FILE_INFO/SMB2_FILE_EA_INFO File: humberto.txt.txt;GetInfo Request FILE_INFO/SMB2_FILE_STRE...
94	5.383609	10.1.253.60	10.1.70.27	SMB2	146	Close Request File: humberto.txt.txt
104	6.652372	10.1.253.60	10.1.70.27	SMB2	354	Create Request File: humberto.txt.txt
107	6.657764	10.1.253.60	10.1.70.27	SMB2	370	GetInfo Request FILE_INFO/SMB2_FILE_EA_INFO File: humberto.txt.txt;GetInfo Request FILE_INFO/SMB2_FILE_STRE...
109	6.664113	10.1.253.60	10.1.70.27	SMB2	275	GetInfo Request FS_INFO/FileFsVolumeInformation File: humberto.txt.txt;GetInfo Request FS_INFO/FileFsAttrib...
111	6.667196	10.1.253.60	10.1.70.27	SMB2	171	Read Request Len=5 Offset File: humberto.txt.txt
113	6.672829	10.1.253.60	10.1.70.27	SMB2	146	Close Request File: humberto.txt.txt

> Frame 81: 354 bytes on wire (2832 bits), 354 bytes captured (2832 bits) on interface 0
 > Ethernet II, Src: HonHaiPr_01:57:df (d8:9c:67:01:57:df), Dst: Cisco_ff:fd:90 (00:08:e3:ff:fd:90)
 > Internet Protocol Version 4, Src: 10.1.253.60, Dst: 10.1.70.27
 > Transmission Control Protocol, Src Port: 25916, Dst Port: 445, Seq: 887, Ack: 1201, Len: 300
 > NetBIOS Session Service
 > SMB2 (Server Message Block Protocol version 2)
 > SMB2 Header
 > Create Request (0x05)
 > StructureSize: 0x0039
 Oplock: Lease (0xff)
 Impersonation level: Impersonation (2)
 Create Flags: 0x0000000000000000
 Reserved: 0000000000000000
 > Access Mask: 0x00120089
 > File Attributes: 0x00000000
 > Share Access: 0x00000005, Read, Delete
 Disposition: Open (if file exists open it, else fail) (1)
 > Create Options: 0x00200044
 > Filename: humberto.txt.txt

Rebuild File SMB



NMAP e WIRESHARK para Segurança da Informação

Aula 25: Wireshark: HTTP

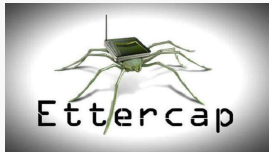
Autenticação HTTP

No.	Time	Source	Destination	Protocol	Length	Info
92	8.464629	10.1.253.60	172.16.45.115	HTTP	741	POST http://testphp.vulnweb.com/userinfo.php HTTP/1.1 (application/x-www-form-urlencoded)
99	8.469120	10.1.253.60	172.16.45.115	HTTP	288	CONNECT clients1.google.com:443 HTTP/1.1
103	8.481272	172.16.45.115	10.1.253.60	HTTP	189	HTTP/1.1 200 Connection established
104	8.481770	10.1.253.60	172.16.45.115	TLSv1.2	571	Client Hello
105	8.543884	172.16.45.115	10.1.253.60	TLSv1.2	116	Server Hello
106	8.544467	172.16.45.115	10.1.253.60	TCP	1514	8080 → 1062 [ACK] Seq=198 Ack=752 Win=16768 Len=1460 [TCP segment of a reassembled PDU]
108	8.544477	172.16.45.115	10.1.253.60	TLSv1.2	630	Certificate
109	8.544478	172.16.45.115	10.1.253.60	TLSv1.2	424	Server Key Exchange
110	8.544479	172.16.45.115	10.1.253.60	TLSv1.2	63	Server Hello Done
113	8.553240	10.1.253.60	172.16.45.115	TLSv1.2	212	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
114	8.648017	172.16.45.115	10.1.253.60	TLSv1.2	60	Change Cipher Spec
115	8.648733	172.16.45.115	10.1.253.60	TLSv1.2	99	Encrypted Handshake Message
117	8.649654	10.1.253.60	172.16.45.115	TLSv1.2	740	Application Data

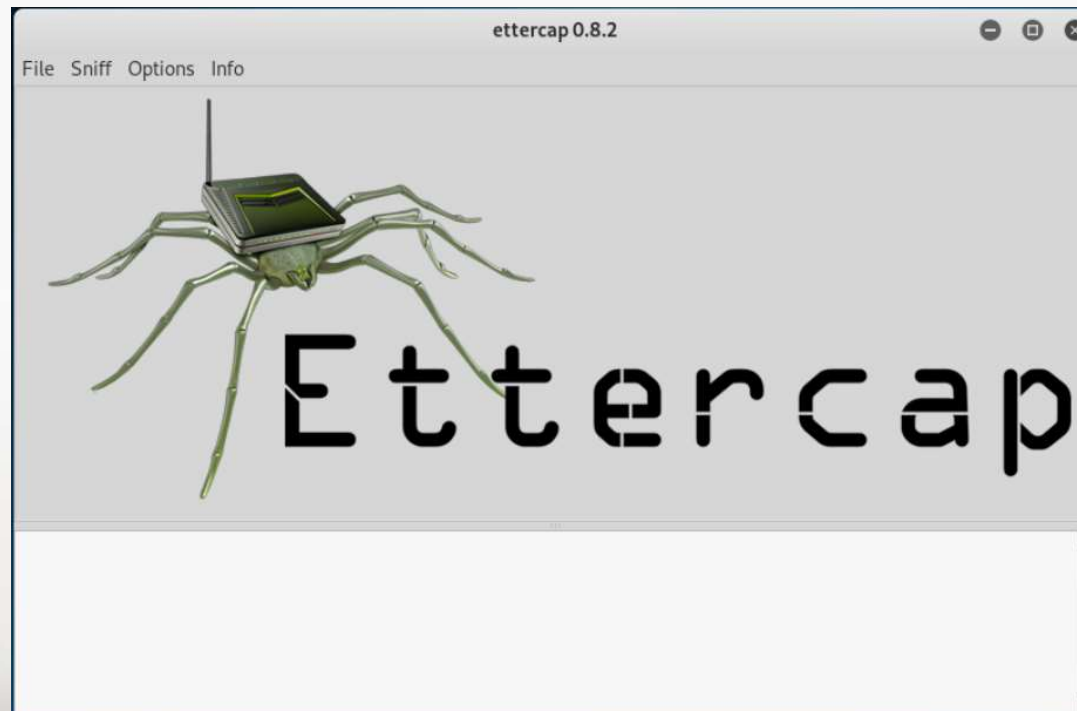
- > Frame 92: 741 bytes on wire (5928 bits), 741 bytes captured (5928 bits) on interface 0
- ▼ Ethernet II, Src: HonHaiPr_01:57:df (d8:9c:67:01:57:df), Dst: Cisco_ff:fd:90 (00:08:e3:ff:fd:90)
 - > Destination: Cisco_ff:fd:90 (00:08:e3:ff:fd:90)
 - > Source: HonHaiPr_01:57:df (d8:9c:67:01:57:df)
 - Type: IPv4 (0x0800)
- > Internet Protocol Version 4, Src: 10.1.253.60, Dst: 172.16.45.115
- > Transmission Control Protocol, Src Port: 1061, Dst Port: 8080, Seq: 1, Ack: 1, Len: 687
- > Hypertext Transfer Protocol
- ▼ HTML Form URL Encoded: application/x-www-form-urlencoded
 - > Form item: "uname" = "teste"
 - > Form item: "pass" = "teste"

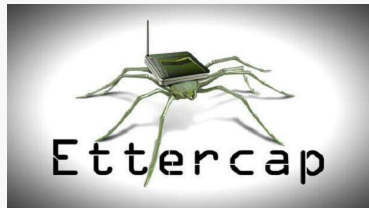
NMAP e WIRESHARK para Segurança da Informação

Aula 26: Realizando Arp Spoofing



Ettercap é um conjunto abrangente para ataques de man in the middle. Ele apresenta sniffing de conexões, filtragem de conteúdo em tempo real e muitos outros truques interessantes. Suporta a dissecação ativa e passiva de muitos protocolos e inclui muitos recursos para análise de rede e host.



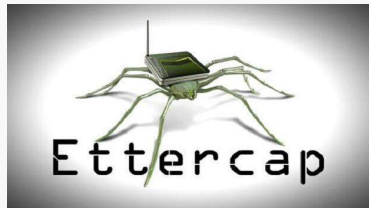


Ettercap é um conjunto abrangente para ataques de man in the middle. Ele apresenta sniffing de conexões, filtragem de conteúdo em tempo real e muitos outros truques interessantes. Suporta a dissecação ativa e passiva de muitos protocolos e inclui muitos recursos para análise de rede e host.

Ettercap + ARP Spoofing

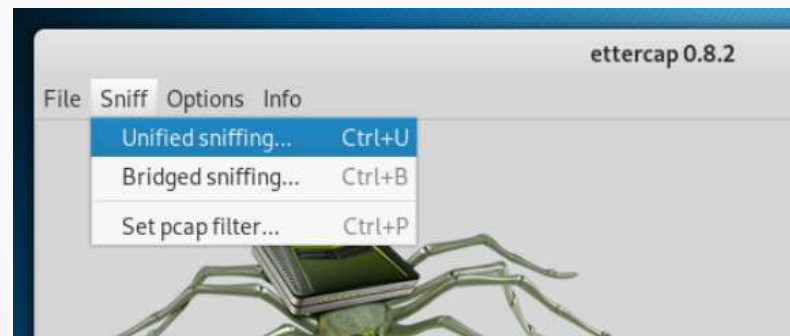
ARP spoofing é uma técnica normalmente usada em redes locais para realizar ataques MITM, DOS ou explorar alguma falha com o propósito de obter acesso ao equipamento da vítima.

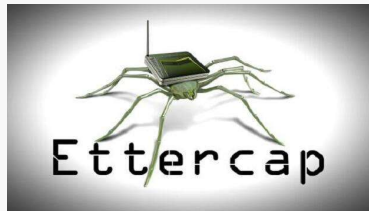
A realização do ataque também pode combinar outras técnicas como DNS spoofing e Sniffing.



Ettercap + ARP Spoofing

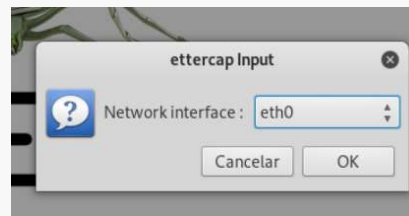
O primeiro passo para lançar nosso anexo MiTM é começar a farejar. Vá para o menu suspenso que diz "**Sniff**" e clique em "**Unified Sniffing**".





Ettercap + ARP Spoofing

Quando fazemos isso, ele abre uma nova janela perguntando qual interface queremos usar e padroniza a eth0.

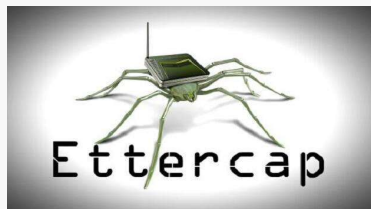


Quando clicamos em "OK", o ettercap inicia o sniffing e carrega seus plugins.

```
Listening on:
eth0 -> 08:00:27:4C:4E:84
192.168.0.132/255.255.255.0
fe80::a00:27ff:fe4c:4e84/64

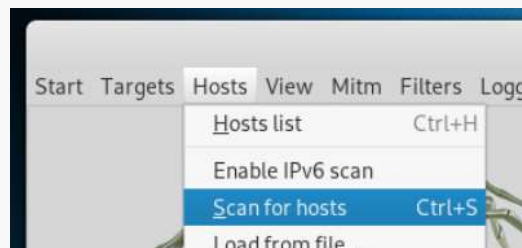
SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Ettercap might not work correctly. /proc/sys/net/ipv6/conf/eth0/use_tempaddr is not set to 0.
Privileges dropped to EUID 65534 EGID 65534...

33 plugins
42 protocol dissectors
57 ports monitored
20388 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!
Starting Unified sniffing...
```

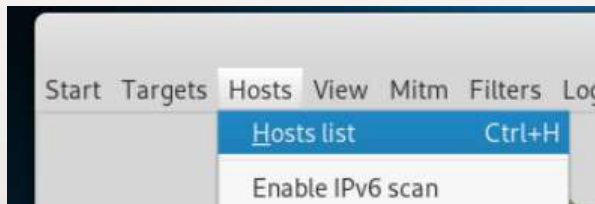


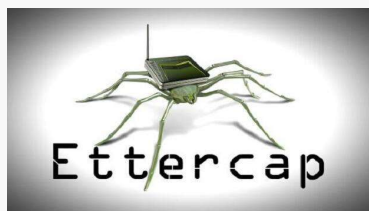
Ettercap + ARP Spoofing

Nosso próximo passo para encontrar os hosts na rede. Clique na aba "**Hosts**" e você verá um menu que inclui "**Scan for Hosts**". Clique nele e o ettercap começará a procurar na rede por hosts.



Agora, usando a mesma guia "**Hosts**", clique em "**Hosts List**". Isso exibirá todos os hosts que o ettercap descobriu em sua rede, como visto na captura de tela abaixo.



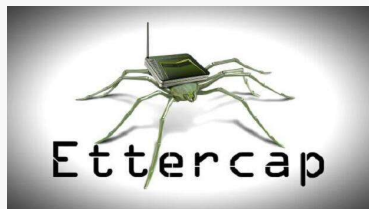


Ettercap + ARP Spoofing

Agora, selecione um dos hosts que serão o alvo desse ataque na janela clicando nele e, em seguida, clique em **"Add to Target 1"** na parte inferior da janela. Quando você fizer isso, o ettercap adicionará esse host como o primeiro alvo em nosso ataque MiTM.

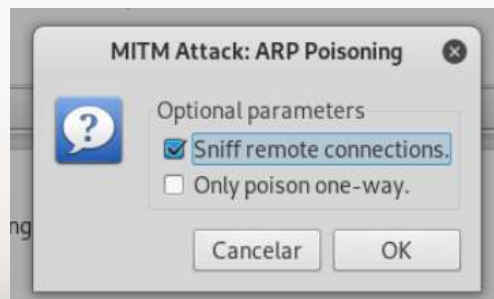
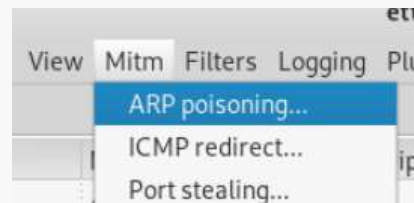


Depois escolha o **"Gateway"** da rede e clique em **"Add to Target 2"** dessa maneira, vamos interceptar o tráfego entre a máquina vítima e o Gateway.



Ettercap + ARP Spoofing

Vá até o menu **MITM** e terá uma seleção chamada "**ARP Poisoning**"



Host 192.168.0.1 added to TARGET2

ARP poisoning victims:

GROUP 1 : 192.168.0.195 08:00:27:99:33:BB

GROUP 2 : 192.168.0.1 AC:84:C6:18:FC:EF

NMAP e WIRESHARK para Segurança da Informação